

存取控制、加解密與金鑰管理

存取控制與身分認證

加解密與金鑰生命週期

認識存取控制(access control)

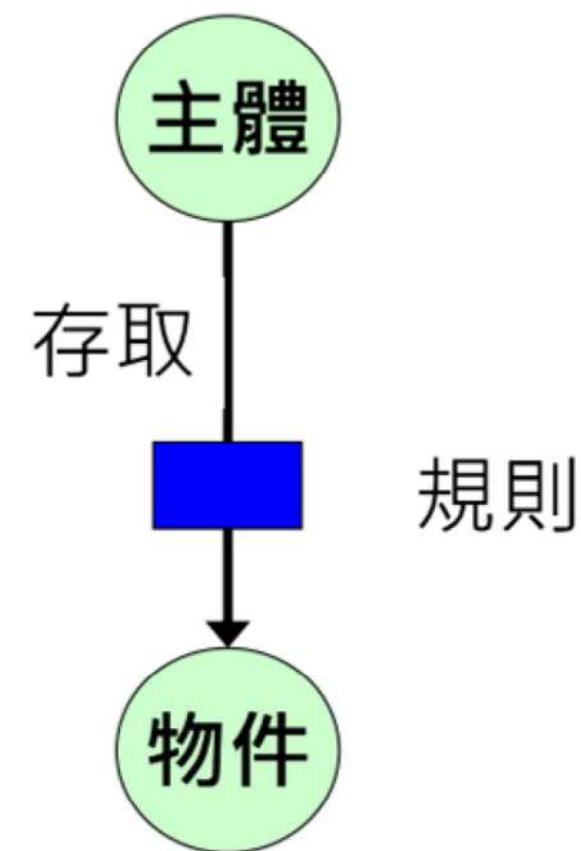
- ◆ 資訊安全中資源使用的控制是非常重要的工作，目的在於保護資源，避免未經允許的使用、修改或洩露。
- ◆ 存取使用控制的方式有很多種，包括技術上的、實質的或是行政管理上的。不管是透過電腦帳號密碼的控管、人員進出的管制，或是企業自訂的規則，都算是存取使用控制的方法。
- ◆ 存取控制(access control)的目的在於管制使用者對資源的使用或是任何的請求對於資源(resources)的存取。
- ◆ 資料是資源的一種。企業把大量資料集中管理，雖有助於資料的處理使用，但在資料的安全性上有隱憂。
- ◆ 資料庫安全、電腦安全及網路安全都有關，三者須密切配合，搭配存取控制，才能達到完整的安全性。

透過存取控制保護資源

- ◆ 資料的安全最主要的涵義是指資料的使用必須受到管制，讓具有權限的使用者得以運用完整而正確的資料。
- ◆ 所謂的「使用者」(**Users**) 可能指人或者是程式，而資料的使用方式可以分成各種不同的型式，這些使用方式的組合，可用來定義使用者的權限 (**Permissions**) ；如此一來，我們才能更有彈性地控制資料的使用。

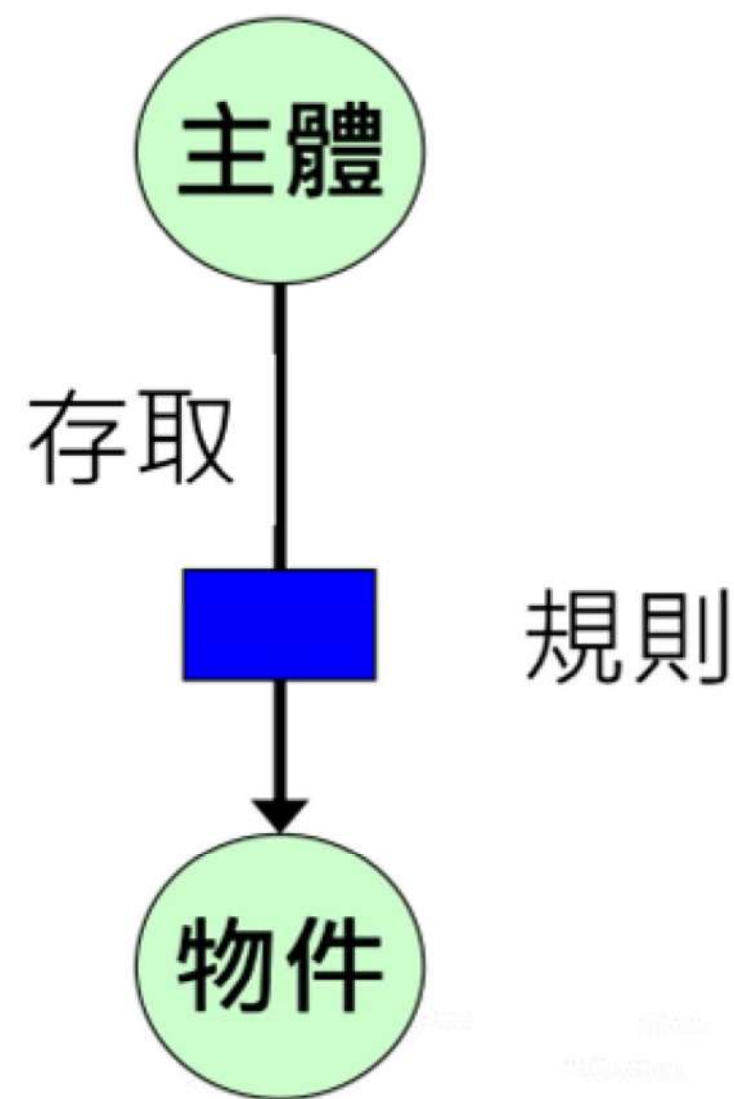
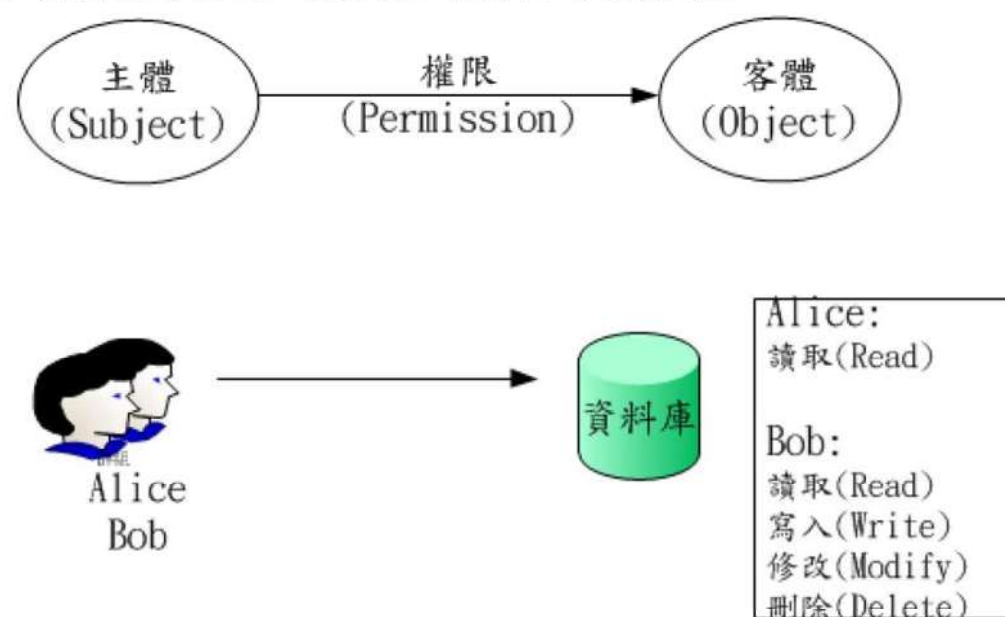
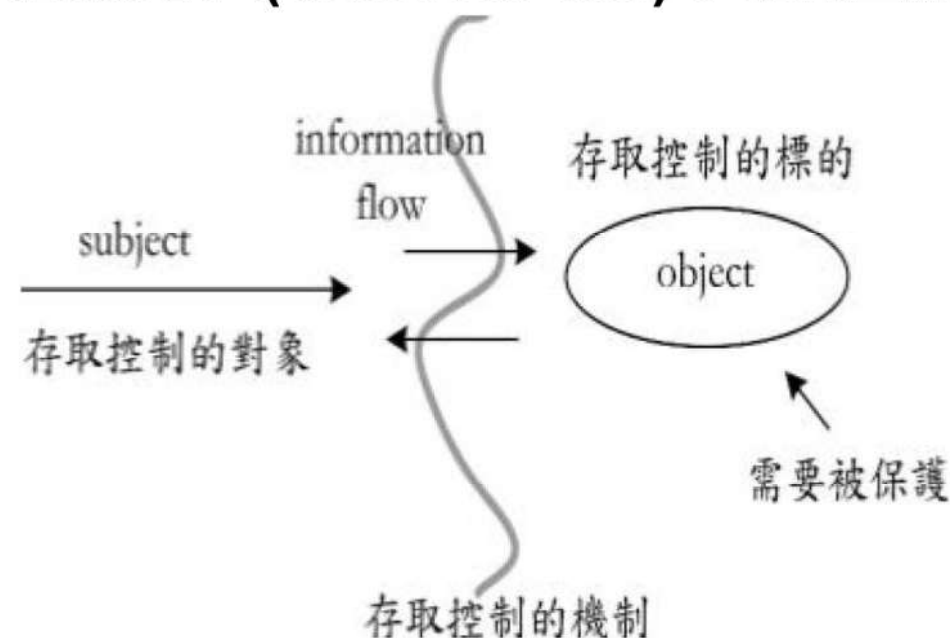
存取控制的基本觀念

- ◆ 資訊安全中資源使用的控制是非常重要的工作，目的在於保護資源，避免未經允許的使用、修改或洩露。
- ◆ 存取控制(access control)的定義：存取控制是指機構用來控制電腦資源被存取的各種機制，機構透過這些機制來控制、限制、監督與保護資源的機密性、完整性與可用性，所以存取控制是針對非法存取的第一道防線。
- ◆ 主體(subject)：主動發起存取行為的個體，主體有可能是一個使用者、或是一個執行當中的程式。
- ◆ 物件(object)：物件是一個含有資訊或是功能的被動個體，接受主體的請求提供資訊或是功能。
- ◆ 存取(access)：存取是指主體與物件之間資訊的流動，例如一個程式對一個檔案進行資料的存取。



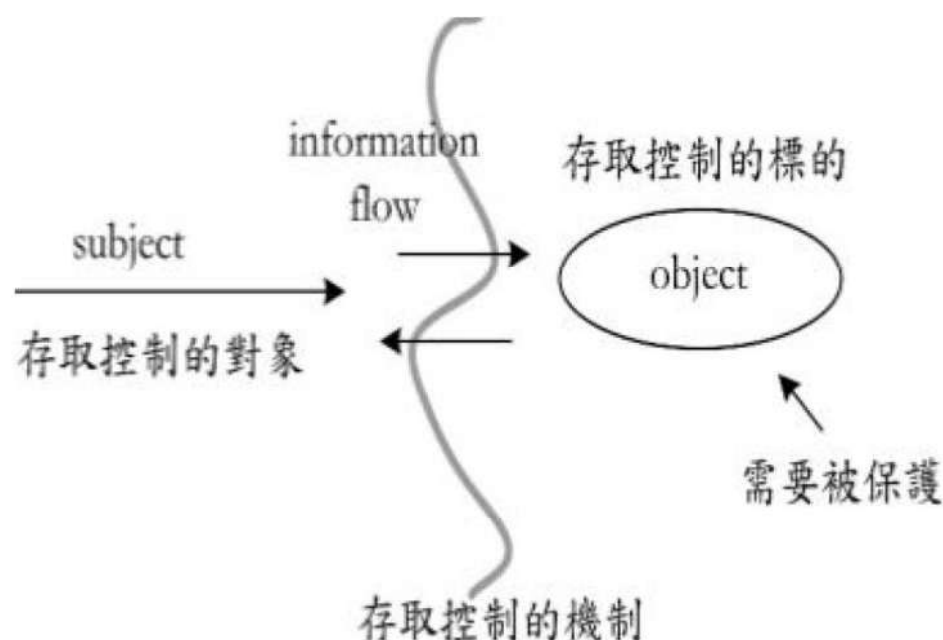
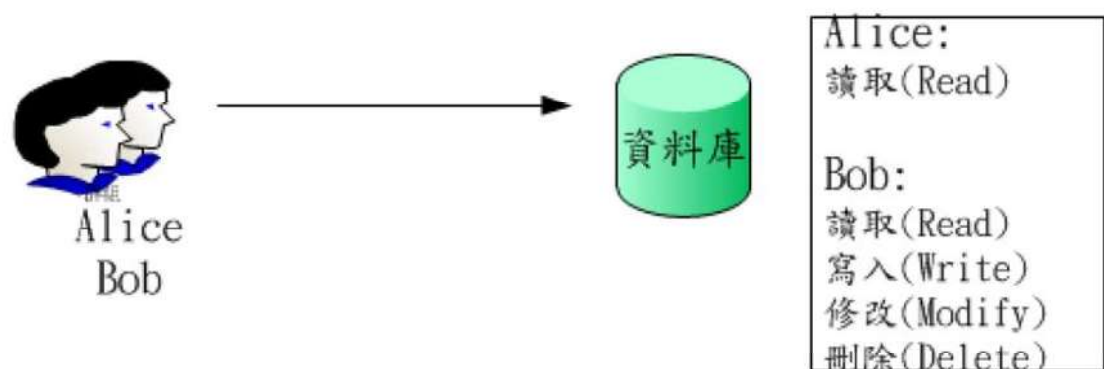
存取控制的定義

- ◆ **主體(Subject)**：主動發起存取行為的個體，通常為資料流的起點。例如：使用者與處理程式。
- ◆ **物件(Object)**：被動存取的個體，通常為資料的接收端與保存端。例如：檔案、資料庫及處理程式。
- ◆ **存取(Access)**：主體對物件進行某些動作，例如：讀取、修改、刪除、建立或執行。
- ◆ **存取規則(AccessRule)**：可強制控管主體與物件之間存取路徑的控制機制。
- ◆ **信賴路徑(TrustedPath)**：確保主體可以存取到其所預期存取到之物件的路徑。



存取控制的對象與標的

- ◆ 可以把存取(access)看成是主方(subject)與受方(object)之間的資訊流通。
- ◆ Subject代表一個主動的個體(active entity)，要求對 object 或是 object 中的資料進行存取。
- ◆ 使用者(user)、程式(program)或處理元(process) 都可能是 subject，需要對 object 進行存取來完成某種工作。
- ◆ 例如一個程式開啟一個檔案的時候，程式是 subject，檔案就是 object。Object 代表一個被動的個體(passive entity)，內含資訊，檔案、資料庫、程式、電腦、目錄或表格的欄位等都可能是 object。



存取控制的類型

- ◆ 在資訊安全的管理上有一個很重要的基礎，就是對資源存取的控制，讓資源得到適當的保護，不會在未經許可的情況下被竄改或是外洩。達到存取控制(access control)的方式可以分為以下 3 大類。
 - **技術類控制(Technical Controls)方法**：運用電腦、通訊與資訊安全方面的技術來進行存取控制。
例如通行碼鑑別、加解密技術、生物特徵識別技術、防火牆系統、入侵偵測及防禦系統。
 - **實體類控制(Physical Controls)方法**：對於可能產生安全疑慮的實體目標要加以管制。
例如門、窗、圍牆、鎖、警衛、重要設施的保護。
 - **管理類控制(Administrative Controls)方法**：把存取控制的安全作業變成企業政策與常規，以適當的管理與責任畫分存取。
例如政策與程序、安全認知訓練、風險管理。

存取控制的功能

- ◆ **防禦性(Preventive)**：讓不當的損害事件不會發生(消除威脅或弱點)。
- ◆ **偵測性(Detective)**：當發生不當的損害事件時可被識別，以利即時處理(入侵偵測與煙霧偵測)。
- ◆ **矯正性(Corrective)**：發生不當的損害事件時可立即防制。
- ◆ **嚇阻性(Deterrent)**：降低威脅發生的意圖。
- ◆ **復原性(Recovery)**：發生不當損害後可回復原來的正常運作。
- ◆ **補償性(Compensation)**：對其他控制措施提供選項的控制措施。

存取控制的管理

- ◆ 存取控制的機制建立以後就會需要適當的管理，透過管理來確認原來規劃的制度按照預期的進度來執行。
- ◆ 存取控制的管理可以分成兩大類：**集中的(centralized)**與**分散的(de-centralized)**，在實務上包括帳號的管理、授權與可歸責性(accountability)

存取控制的管理類型

◆ **集中的(centralized)存取控制管理**：由一個人或是一個部門來綜理企業資源的存取控制，設定好存取控制的機制、處理使用者存取控制的更動、授權與取消授權等。

這樣的管理方式容易維持一致性，不過由於所有的工作都集中在單一的個人或是部門，可能會造成作業上的瓶頸。

◆ **分散的(de-centralized)存取控制管理**：將存取控制交由接近資源的人來處理，這些人最了解資源使用的特性。

例如維修部門的經理很清楚每個維修人員的職責，可很快完成資源存取控制的設定，假如還要層層提報，反而效率不彰。

一旦授權分散了，由多人執行，就有可能標準不一，而且容易造成漏洞。

存取控制的管理

◆帳號管理(身分識別與鑑別)：

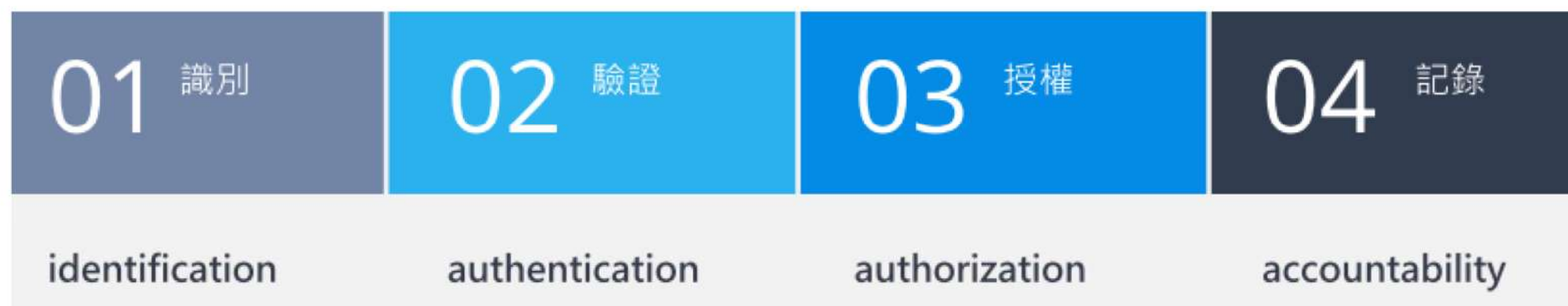
- 身分識別(**Identification**)：主體告知身分識別資訊。例如：帳戶、使用者代號及使用者名稱。
- 身分鑑別(**Authentication**)：驗證身分識別資訊的技術。例如：通行碼、生物特徵及動態通行碼。

◆授權(Authorization)：

- 決定主體是否能夠存取物件的判斷準則。

◆可歸責性(Accountability)：

- 稽核紀錄(Auditing)。
- 存取行為不可否認的機制。



主體取得對物件存取權限的經過

01 識別

identification

主體提供識別的資訊，例如使用者名稱、使用者帳號等，足以識別為系統中有記載的個體

02 驗證

authentication

驗證主體是否確為本人，通常主體要提供驗證的資訊，例如對應到帳號的密碼，或是生物特徵等足以驗證的要件

03 授權

authorization

在通過識別與驗證之後，主體等於通過了檢查，但是接下來能有什麼權限仍然要由系統確認

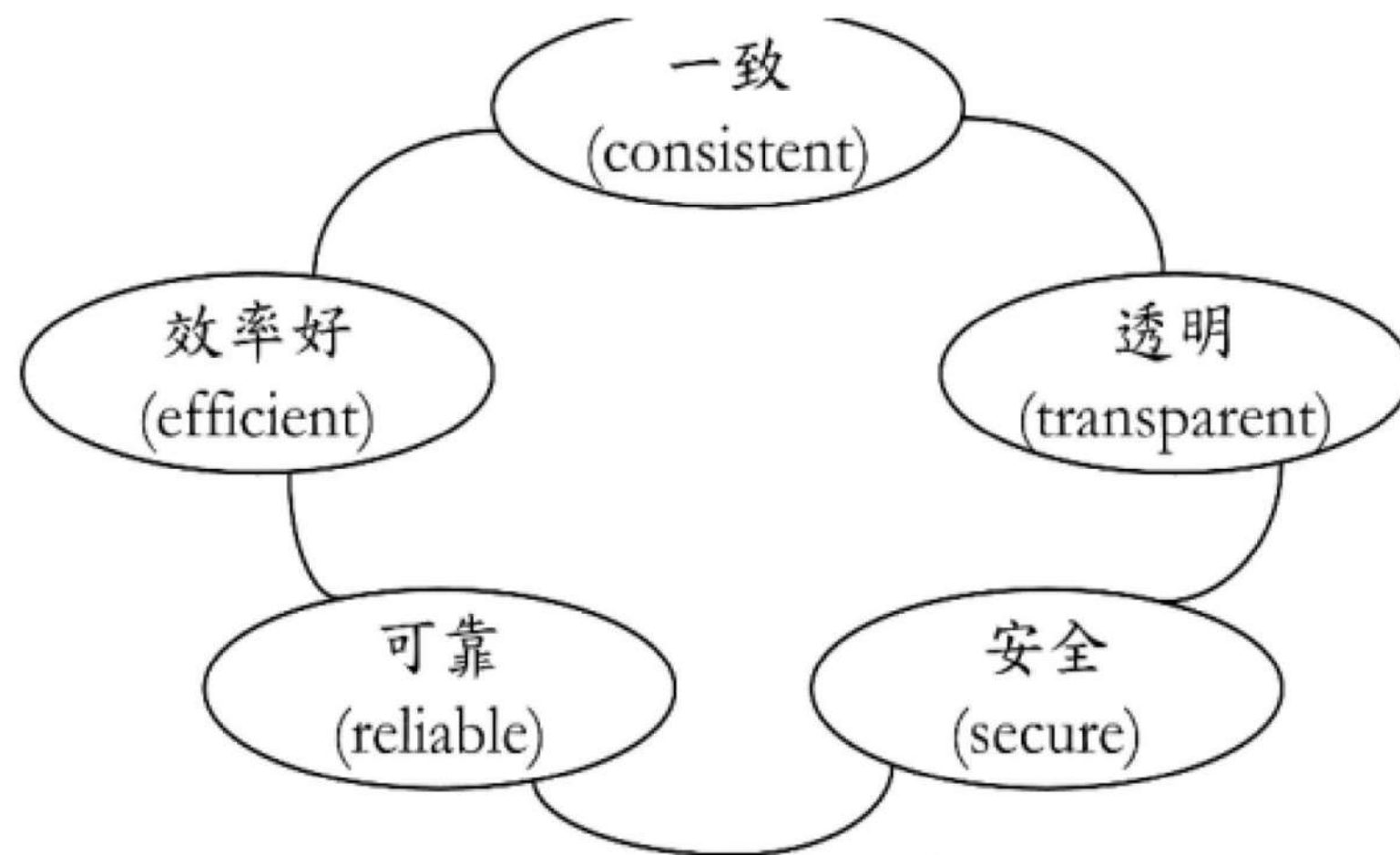
04 記錄

accountability

主體開始存取物件以後的動作都會被記錄下來，成為稽核所需要的依據

存取控制的技術

- ◆ 大家一定聽過指紋辨識、人臉辨識或是通關密碼，這都能用來做為存取控制的技術，越精準的技術達到的效果越好。
- ◆ 存取控制措施要具備的特性：工具的使用可以讓存取控制的工作得以自動化，降低行政成本、提昇安全，同時改善企業整體的服務品質。存取控制措施必須要具備一些基本的特性。



身份的識別與鑑別

◆ 進行身份的識別與鑑別通常會用 3 種條件：

➤ 使用者所知道的(something a person knows)

➤ 使用者所擁有的(something a person has)

➤ 使用者所具有的(something a person is)

◆ 所謂的強力的驗證(strong authentication)是指驗證的時候至少用到上述的其中兩種條件，這樣可以讓駭客更難偽裝或是破解。

身份認證因素

- ◆ 你是(Something you are)：指紋
- ◆ 你有(Something you have)：晶片卡
- ◆ 你知(Something you know)：通行碼



生物特徵度量(biometrics)

◆ **生物特徵度量(biometrics)**是透過個人特徵或行為的分析來判定身份，是相當有效而精確的鑑別方法。

由於生物特徵度量的技術很複雜，建置的成本比較高。

◆ 個人身上的特徵通常不會改變，鑑別時很準確。所謂的個人特徵包括眼睛虹膜(iris)、視網膜(retina)與指紋。

◆ 生物特徵度量系統(biometric system) 預先登載使用者的特徵，使用者要求識別時，可比對輸入的特徵。

◆ 但是系統有可能把本人錯認為偽裝的(false negatives)，或是把偽裝者當做是本尊(false positives)。

◆ 因此系統必須做經常的校準，維持準確性，也必須同時設法降低錯誤。

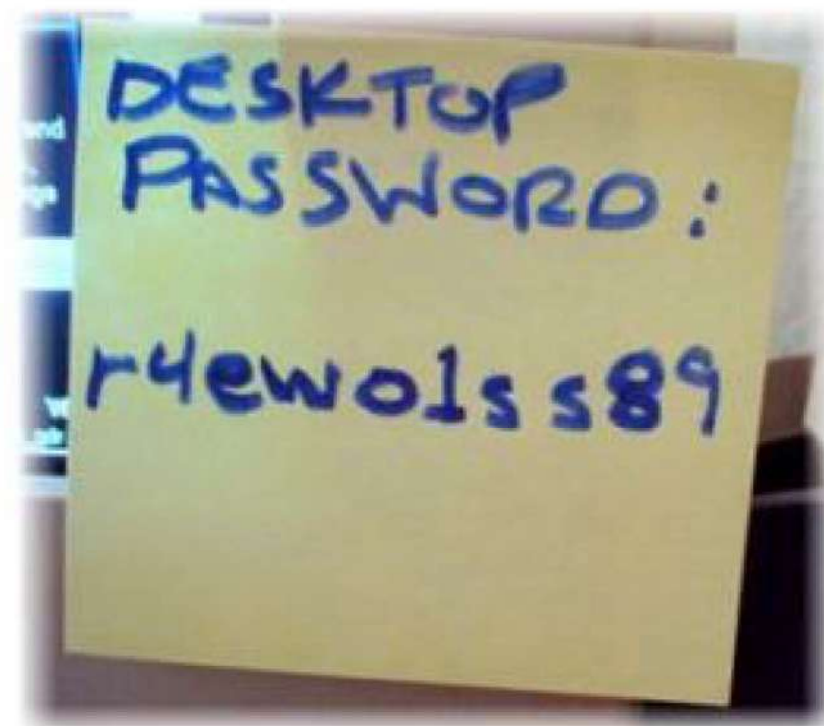
密碼(password) 與智慧卡(smartcards)

- ◆ **智慧卡**：智慧卡有處理資訊的能力，卡片積體電路含有處理器。智慧卡運用的是二元驗證方法(two-factor authentication)。要擁有智慧卡且輸入 PIN 才能使用。
- ◆ **密碼**：使用者在識別成功之後再輸入一個密碼是常見的系統識別與驗證的機制，密碼只有使用者自己知道，直到目前為止，我們進入大多數的系統之前都需要輸入密碼。

通行碼身分鑑別技術

◆目前使用「最廣泛」也「最簡便」的身分鑑別技術，也是最不安全的身分鑑別技術

- 使用者選用了「懶人通行碼」
- 共用通行碼
- 將通行碼貼在螢幕上
- 從不更改通行碼
- 輸入通行碼時被別人看到按下的通行碼



◆針對通行碼的攻擊

- 通行碼監聽
- 字典猜測法
- 暴力式通行碼猜測

通行碼身分鑑別技術

◆ 避免通行碼被破解的防護措施

- 系統強制要求長度至少8碼，包含文字、數字及符號、包含大小寫，在字典中查不到、以中文字注音符號按鍵來設定
- 系統強制要求使用者定期更換通行碼
- 由系統判斷通行碼不重覆使用
- 可限制通行碼容許簽入失敗的次數
- 簽入成功或失敗都應被記錄
- 使用通行碼檢測工具尋找脆弱通行碼
- 通行碼不以明碼方式儲存
- 通行碼不以明碼方式在網路上傳送
- 加強保護集中存放通行碼的伺服器

OTP 一次性密碼



- ◆ 一般的靜態密碼在安全性上容易因為木馬與鍵盤側錄程式等而被竊取，而只要花上相當程度的時間，也有可能被暴力破解。
為了解決一般密碼容易遭到破解情況，因此開發出一次性密碼的解決方案。
- ◆ 一次性密碼（英語：One Time Password，簡稱 OTP），又稱動態密碼或單次有效密碼，是指電腦系統或其他數位裝置上只能使用一次的密碼，有效期為只有一次登入或交易。
- ◆ OTP 避免了一些與傳統基於（靜態）密碼認證相關聯的缺點；一些實作還納入了雙因素認證，確保單次有效密碼需要存取一個人有的某件事物（如內建OTP電腦的小鑰匙掛件裝置）以及一個人知道的某件事物（如PIN）。
- ◆ 相對於靜態密碼，OTP 最重要的優點是它們不容易受到重放攻擊(replay attack)。這意味著管理記錄已用於登入到服務或進行交易的 OTP 的潛在入侵者將無法濫用它，因為它將不再有效。
- ◆ 第二個優點是，使用多個系統相同（或類似）密碼的用戶，如果其中一個密碼被攻擊者獲得，不是對所有的系統都容易變得脆弱。
- ◆ 許多 OTP 系統也確保會話不能輕易被截獲或沒有前一個會話期間產生不可預測資料的知識類比，從而進一步減少攻擊面。

OTP 一次性密碼

◆ 一次性密碼(One-Time Password) 或稱為動態通行碼

- 由隨身攜帶的代碼(Token)或軟體自動產生簽入用通行碼。
- 簽入時每次產生的通行碼只能使用一次。
- 可防止通行碼被竊聽而偽冒簽入的問題。
- 可防止通行碼猜測攻擊。



單一登入(single sign-on)

- ◆ 企業運算設備都會不斷地擴充，軟體應用之間的相關性也持續增加。伺服器、資料庫與各種資源越來越多，使用者常要有多組的帳號與密碼登入各種系統。主從架構的普及使這種現象更普遍。但對使用者來說，要記得多組帳號密碼很麻煩，系統管理者也常接到忘記密碼的問題，因此有人想到單一登入(SSO, single sign-on)的技術。
- ◆ 在 SSO 的技術下，使用者只要登入一次，就可以使用所有該帳號授權使用的資源。
對於使用者來說，不用再記得多組帳號密碼，管理者也可以簡化權限的管理。
不過對於駭客來說，只要竊取一個帳號，即可取得多種資源與系統的使用權限，所以潛在的威脅更大。

授權原則

- ◆ 由於人員可能流動，因此應定期審查存取權限，以確保其有效性。
- ◆ 存取權限之授予標準主要包含以下內容：
 - 必須知道(need-to-know)：只提供執行業務上所需知道的資訊。
 - 最小授權(least privilege)：權限開放時採用最低權限原則。
 - 權責區隔(Segregation of Duty, SOD)：「重要」的工作任務可切割由多人負責，避免需共謀進行的惡意行為。
例如，掌管存取安全的人員不應擔任安全稽核的工作。
 - 可歸責性(accountability)：使對某一行為負責的狀態；對作為或不作為所負的責任。
 - 可追溯性(traceability)
- ◆ 僅給予職務執行上所必須知悉之內容，並設定明確的權責歸屬，針對各個職務內容考量法規、合約及內部要求，以利維護隱私權(privacy)及機密性(confidentiality)、完整性(integrity)與可用性(availability)等資訊安全要素。

授權原則

- ◆ **預設無存取權(default to no access)**：存取控制機制對於使用權限的基本預設值應該是無存取權(default to no access)，這樣才能確保系統沒有漏洞。所以在授權的時候，應該從毫無權限的情況開始，慢慢加入需要的權限。
以存取控制清單(ACL, access control list)來說，上頭有記載的才是允許的授權，沒有記載的就不能授權。
- ◆ **最少權限的原則(need to know principle)**：所謂的「**僅知需知**」(need to know)是指使用者只擁有工作真正需要的資源使用權限。這種授權的原則是盡量少給權限，甚至於使用者只有在限定的期間才有權限。當然，管理者本身並沒有權利去限制使用者的權限，授權的決定權在於管理階層，一旦授權方式決定了，未來出問題時管理階層必須負責。

可歸責性(Accountability)與稽核

- ◆ 稽核的機制可以確認使用者在資源存取過程中應負的責任，檢驗安全政策是否確實，而且可以當做調查時的工具。
- ◆ 所謂的可歸責性(Accountability)其實就是追究安全事件發生因果的機制，能夠追究出來就可以確定責任的歸屬。
 - 01.從發生的安全事件追究出相關的個人
 - 02.偵測入侵
 - 03.重建事件與當時的系統條件
 - 04.發現異常現象
 - 05.提供行使法律所需要的文件與問題發生的報告

稽核記錄的項目

稽核記錄的項目類別	說明
系統層次的事件(system-level events)	系統效能(system performance)
	登入的嘗試(包括成功與失敗的)
	登入的帳號(logon ID)
	登入的時間與日期
	使用者與終端機被鎖定(lockouts)的情況
	管理功能與指令的使用
	使用的設備
	執行的功能
	改變設定檔案
應用層次的事件(application-level events)	錯誤訊息
	開啟與關閉的檔案
	檔案的修改
	應用程式中產生的違反安全規則的情況
使用者層次的事件(user-level events)	識別與驗證的嘗試
	使用的檔案、服務與資源
	使用的指令
	違反安全規則的情況

存取條件(access criteria)

◆ 由於系統管理的資源很多，授權的細節會很複雜，不過越詳細表示可以對資源的存取做越精密的管控。

◆ 假如資源的存取控制只是完全容許使用或是完全拒絕使用，則對於使用者或是管理者來說就太沒有彈性了。

必須要有更細微的存取控制的授權機制。可以採用的辦法就是存取條件(access criteria)的設定。以下是一些存取條件的設定

➤ 角色(roles)

➤ 群組(groups)

➤ 位置(location)

➤ 時間(time)

➤ 交易類型(transaction types)

存取控制的方法

- ◆ 存取控制有 3 大類：行政的(administrative)、技術的(technical)與實體的(physical)，每一類的存取控制都有不同的存取控制機制，在執行上可能是人為的或是自動進行的。



各種類型存取控制的實務

存取控制的分類	成員	存取控制的分類	成員
管理的控制 (administrative controls)	政策與程序	技術的控制(technical controls)	系統的存取
	人員的管理		網路架構
	監督的架構		網路的存取
	安全警覺的訓練		加密
	測試		稽核(auditing)
存取控制的分類	成員		
實體的控制(physical controls)	網路的分割		
	周邊安全(perimeter security)		
	電腦控制		
	工作區域的分隔		
	資料的備份		
	佈線(cabling)		
	控制區域(control zone)		

存取控制作業實務的日常作業列表

項目	說明
1	拒絕匿名或是無法辨識的帳號登入系統
2	限制管理者帳號與特殊帳號的使用，並加以監督
3	盡速移除無效不再使用的帳號
4	暫時凍結長時間未使用的帳號
5	嚴格執行存取條件的檢查
6	停止不需要使用的系統功能、服務與通訊埠
7	改掉帳號的預設密碼(default password)做法
8	限制全域式的存取(global access)規則
9	確認登入的帳號名稱與工作性質無關
10	將帳號與群組設定中多餘的資源存取規則移除
11	從資源的存取清單中移除重複的使用者帳號、角色類型的帳號
12	確保密碼經常更換
13	確保密碼的設定符合安全規定
14	稽核系統與使用者的活動，並且定期檢視
15	保護稽核資訊
16	確實執行最少權限(least privilege)的原則
17	對於失敗的登入帳號實施暫時凍結的處理

實體環境的存取控制

◆存取控制的角色

- 主體：人員
- 物件：機房、線路室、保險櫃及電腦等
- 存取規則：只有在職員工能從1F大門進出
- 強制信賴路徑：2M圍牆加電網、獨棟建物且與其他建物棟「距20M以上」

◆存取控制的管理

- 鑑別：門口警衛檢查人員通行證
- 授權：通行證有效且為在職員工者放行，無效或非在職員工則不放行
- 可歸責性：登記人員進出的時間、目的、攜入或攜出的物品

作業系統的存取控制

◆存取控制的角色

- 主體：人員與執行中的程式(Process)
- 物件：檔案、資料庫、其他執行中的程式及記憶體等
- 存取規則：通行碼檔案只能被管理者存取
- 強制信賴路徑：所有磁碟機的檔案存取由OS控制，一般程式不能直接存取磁碟機，使用者所執行的程式繼承該使用者的身分與權限

◆存取控制的管理

- 鑑別：簽入作業(帳號通行碼比對正確)
- 授權：是否為管理者群組？是否符合檔案存取權限？
- 可歸責性：檔案開啟、修改及刪除都被記錄下來，包含時間與存取者等

應用系統的存取控制

◆存取控制的角色

- 主體：人員
- 物件：檔案與資料庫等
- 存取規則：只有主管才能簽核其部屬的假單
- 強制信賴路徑：所有簽核動作集中於個別程式處理，且配合電子簽章技術

◆存取控制的管理

- 鑑別：應用程式簽入作業(帳號通行碼比對正確)
- 授權：是否為主管？請假人是否為其部屬？
- 可歸責性：所有簽核動作都應記錄，包含時間、申請人、簽核人及簽核結果等

存取控制的常見威脅

- ◆ 很多資安攻擊會先嘗試攻破存取控制的保護，接著就能對系統與資源取得完整的控制，平時必須對常見的攻擊手法保持警覺。
- ◆ **存取控制可能遭遇的威脅：**企業資訊安全所受到的威脅可能來自外部、也可能來自內部。一般人可能以為攻擊或不法的行為都來自外部，其實內部的威脅往往更嚴重，因為外部的駭客必須經過層層的防禦才能接觸到企業的重要資源，而內部的不軌員工不但已經具有一些使用權限、而且更熟悉內部的作業，也得到初步的信任，反而更容易產生更大的危害。

存取控制的常見威脅 - 字典攻擊(dictionary attack)

◆ **攻擊方式：**駭客可以利用程式來自動比對密碼檔案的資料與以任意字元組合形成的密碼，通常密碼檔案都有經過雜湊 (hashing) 的處理，所以程式在設計上可以從字典取得字元，經過組合與雜湊的處理以後再去比對。

一旦成功，等於取得了登入系統的帳號與密碼。

◆ **防治的方法：**避免以明文來傳遞密碼，密碼選用時盡量選擇難以猜出的字元組合，最好在密碼中包含特殊字元。

平時最好經常改變密碼，管理者也可用字典攻擊來發現是否有使用者的密碼設的不好，或是用入侵偵測系統發現可疑的登入活動，密碼檔案要善加保護。

存取控制的常見威脅 - 蠻力攻擊(brute force attack)

◆ 攻擊方式：

- 蠻力攻擊(brute force attack)透過輸入值的變化來持續地嘗試，直到成功為止。
- 所以假如想破解的是密碼，就嘗試各種密碼直到猜到為止。通常駭客可以先用字典攻擊猜出部分的密碼，再用蠻力攻擊試其他剩餘的組合。

- ## ◆ 防治的方法：
- 直接對自己的系統進行蠻力攻擊就可以先發現一些弱點所在，對於可疑的活動要加以記錄與稽核，透過入侵偵測系統監控可疑的活動，對於可疑的嘗試次數設定上限。

存取控制的常見威脅 - 假造的登入畫面(spoofingat logon)

◆ 攻擊方式：

- 駭客可在使用者的電腦上先執行一個假造的登入畫面，使用者不疑有它，直接輸入帳號與密碼，駭客程式把帳號密碼記錄下來，顯示一個輸入錯誤的訊息，然後終止程式。
- 使用者並不覺得自己被騙了，會以為方才按鍵不小心輸入錯誤。網路釣魚(phishing)常用這樣的技倆，模仿大型商業網站的畫面來詐騙。

◆ 防治的方法：作業系統本身可設定成顯示錯誤的登入次數，使用者下回登入時若沒有發現這樣的訊息就會起疑心。

對於收到的 e-mail 中有超連結的部分，不要輕易點選；注意釣魚的網站往往跟正常的網站在網址上有些微的差異，讓人以為是相同的網站。在上網傳送敏感資訊時，最好都使用 SSL 的連線，也就是網址以 https:// 開頭的連線。

認識密碼學

- ◆ 密碼學(cryptography)，是指探討讓資訊能不讓人輕易解讀的學問。很久以前就有這種需求，而在電腦與網路普及以及駭客充斥的現代，密碼學的發展更進一步，重要性大增。
- ◆ 密碼學是一個能夠安全地儲存與傳遞資料的方法，讓真的有權限的人能夠讀取與處理被保護的資料，其他人無法使用被密碼學的方法保護的資料。
- ◆ 基本的做法是把原來的資料轉換成無法直接讀取的格式。但要真正有效地透過這種方式來保護資料，需要一些理論與數學上的探討。

密碼學的演進

◆ 密碼學比較好的詮釋應該是一種秘密的通訊，目的是避免讓我們想保密的資訊被敵人看到或取得。

在資訊時代，密碼學的基本作用是建立一種通訊的方式讓收訊者能解讀訊息、非收訊者無法解讀。

通訊方式能輕易地調整，例如改變密碼。

➤ **古典密碼學**：強調資訊的保密撰寫與傳遞，以及解譯的方式，編碼與解譯與設計者及破解者技巧有關。

➤ **現代密碼學**：除了要做到資訊保密，還要能進行資訊完整性的驗證，已發展出系統化與嚴謹的理論。

➤ **密碼分析**：目的在於發現密碼機制的弱點，嘗試破解，所以密碼學的演算法與協定要具備安全性。

密碼學的實際應用



對資料的保護

不管資料是在儲存狀態或是在傳遞中，都可以透過加密來達到保護的效果，也就是不要讓沒有權限的人取得並解讀資料，這樣就維持了資料的**機密性**，因為也無法修改，所以保全了**完整性**



身份鑑別

任何人提供資料或是進行交易都需要做身份的鑑別，這樣事後才**無法否認**所提供**資料的來源真實性**或是否認曾經行使特定的交易。在電子交易或是政府機關提供個人資料時都須鑑別對方的身份



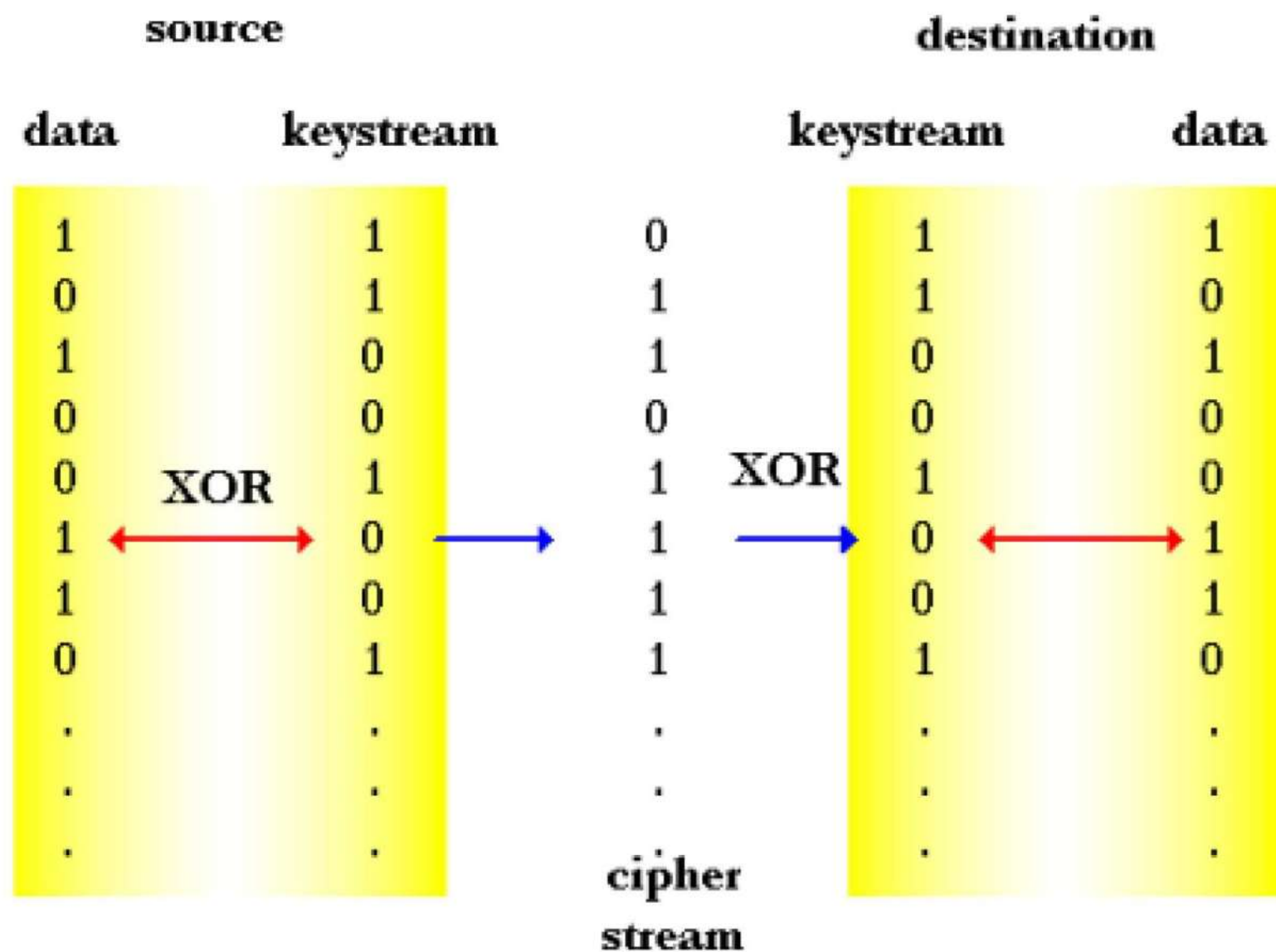
支援特定的資安作業

有的資安作業可運用密碼學的技術，例如須毀損的硬碟在破壞之前可先將裡頭儲存的資料加密，避免為破壞完全時讓人取得裡面的資料。雖然也算是對資料的保護，但主要是彌補儲存裝置毀損作業可能產生的風險

密碼學加解密的實例

◆ 串流加密使用位元串流，當做金鑰串流(key stream)，金鑰串流與原始的訊息(message)結合產生密文(cipher text)。

接收端使用相同的金鑰串流將密文還原成原始的訊息。RC4 使用 XOR(exclusive OR)的運算來處理加密與解密。



關於「密碼」與「金鑰」的迷思

- ◆ 電腦系統的存取控制常使用帳號與密碼(password)來限制，使用者輸入帳號以後，還要輸入正確的密碼才能登入系統。

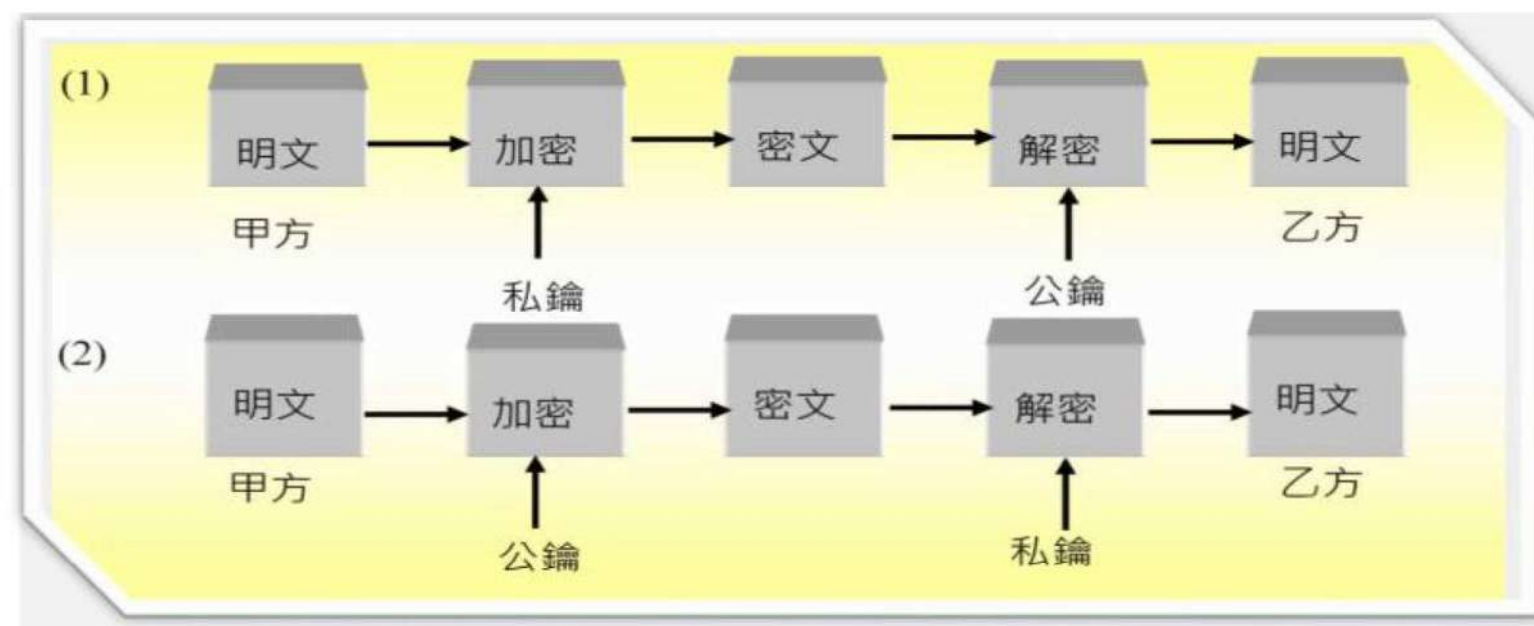
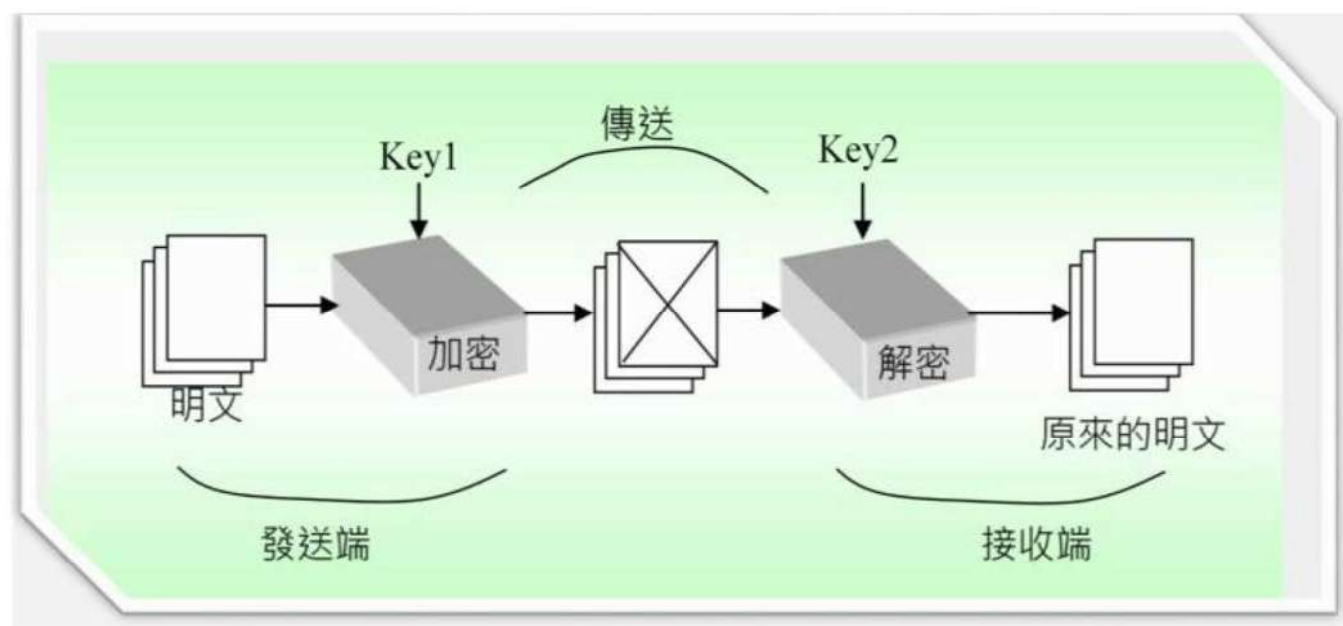
這種密碼也稱為通行碼(passphrase)，系統比對正確之後就會放行。

- ◆ 密碼學裡頭常使用金鑰(key)來對資料加密，金鑰須搭配演算法來對資料進行加密(encryption)或是解密(decryption)，

所以 password 與 key 兩者的概念是不同的。

加密法的基本原理

- ◆ 所謂加密的方法其實也包括解密的方法，主要的目的是把資料變成無法直接解讀的格式，必須取得金鑰與演算法才能還原資料使用。
- ◆ 加密的經過：發送端要傳送的訊息以「明文」(plaintext)稱之，用金鑰(key)加密之後成為無法用一般方式讀取的「密文」(ciphertext)，然後傳送到接收端，利用金鑰解密後，還原成可讀取的明文。

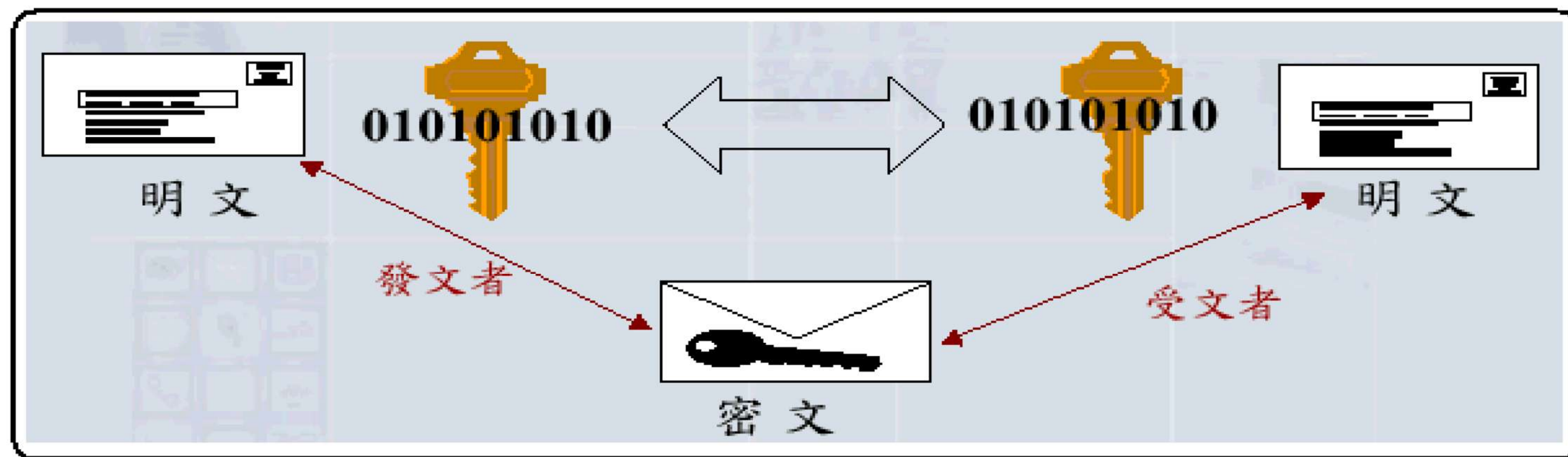


對稱式的加密法

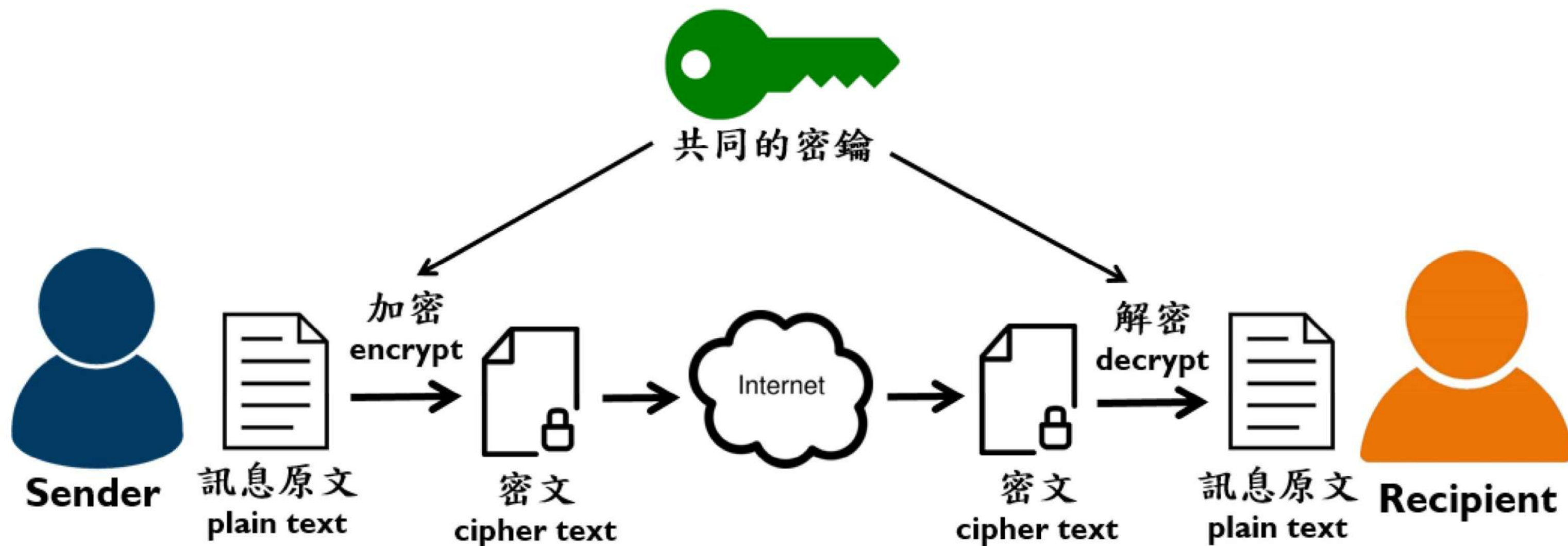
◆對稱金鑰加密技術

- 加密演算法使用的金鑰加密演算法可分為兩種，一種為對稱式金鑰加密法，另一為非對稱式金鑰加密法。
- 對稱式金鑰加密法所使用之加密及解密之金鑰，為相同一把金鑰，意指使用相同一組密碼來加解密。
- 使用對稱式金鑰加密的好處在於其加解密速度快。
- 常見的對稱金鑰演算法如下：
 - 資料加密標準 (DES)
 - 三重DES
 - RSA的對稱金鑰演算法
 - RC2、RC4、RC5和RC6
- 多數安全專家認為DES和三重DES不再能滿足安全需要。1997年1月，NIST開始確定接替DES演算法的程式，決定所選的對稱金鑰演算法被稱做高級加密標準 (Advanced Encryption Standard)。

對稱式金鑰加密技術原理

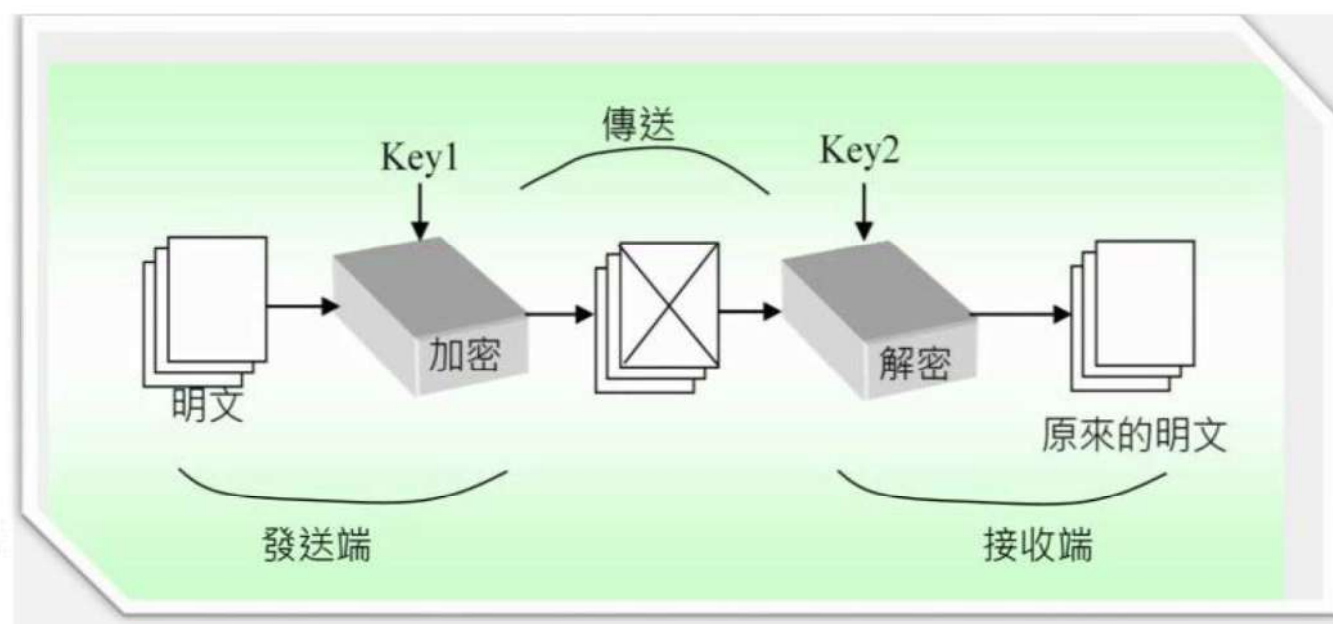


對稱式金鑰加密技術原理



對稱式的加密法

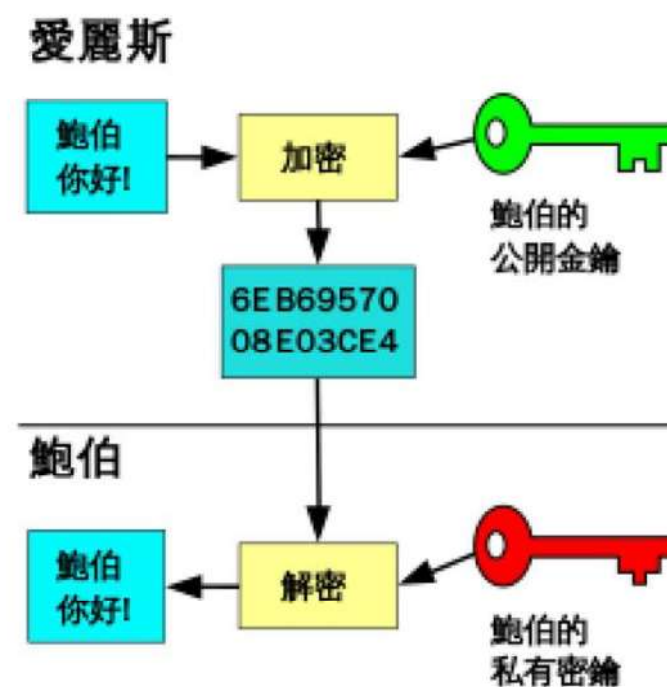
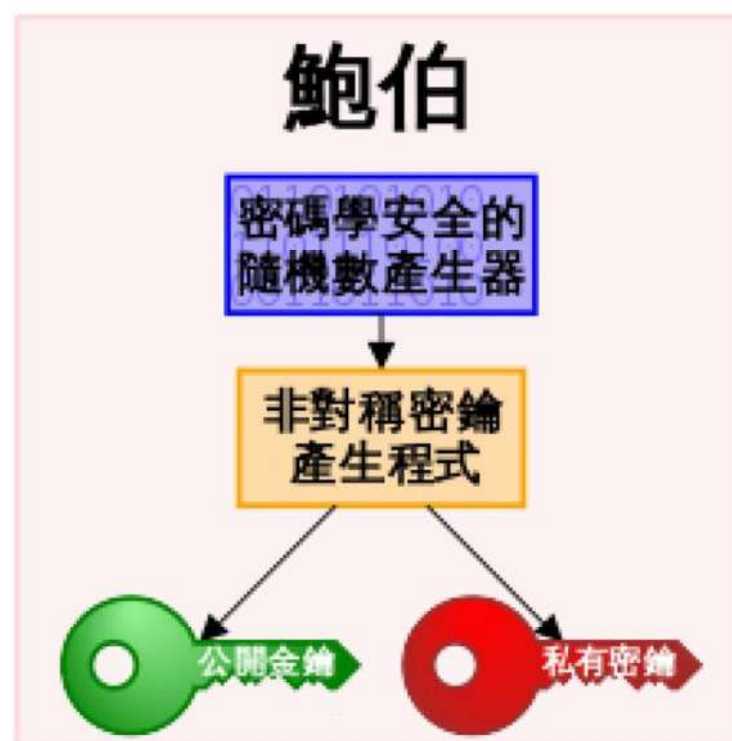
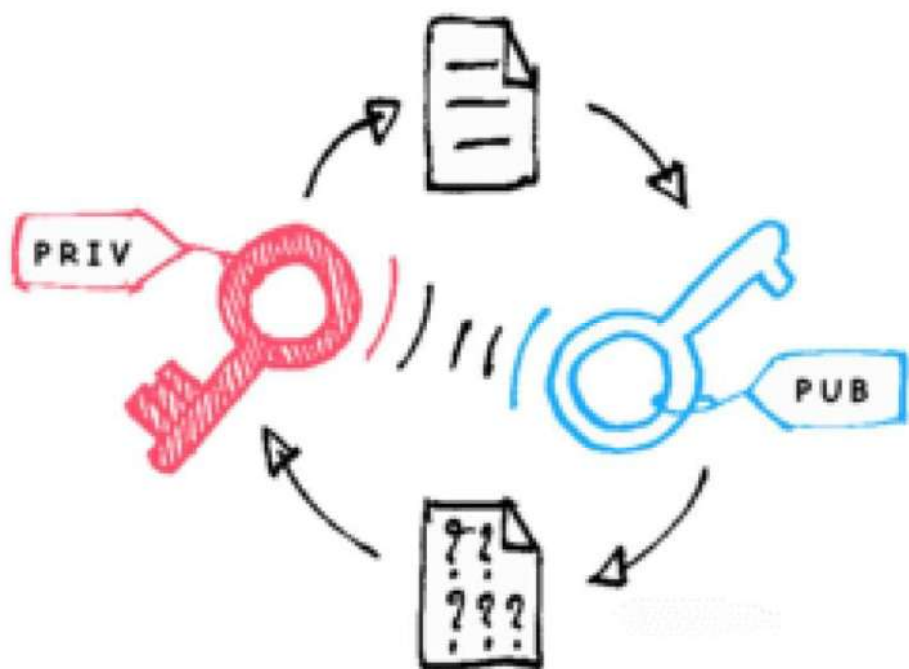
- ◆ **對稱式的加密**：由於密文無法讀取，我們可以說這種方式幫助維持資料的私密性。假如圖中的 key1 和 key2 相同，則可稱之為「對稱式的加密」。
- ◆ 常見的對稱式加密法包括 DES、Triple-DES、RC2、RC4、RC5、RC6 與 AES。
 - 優點是加解密快速。若金鑰夠長則安全性高。
 - 缺點是加密對象多，則金鑰的保護與交換複雜，支援機密性，但無法支援不可否認性。



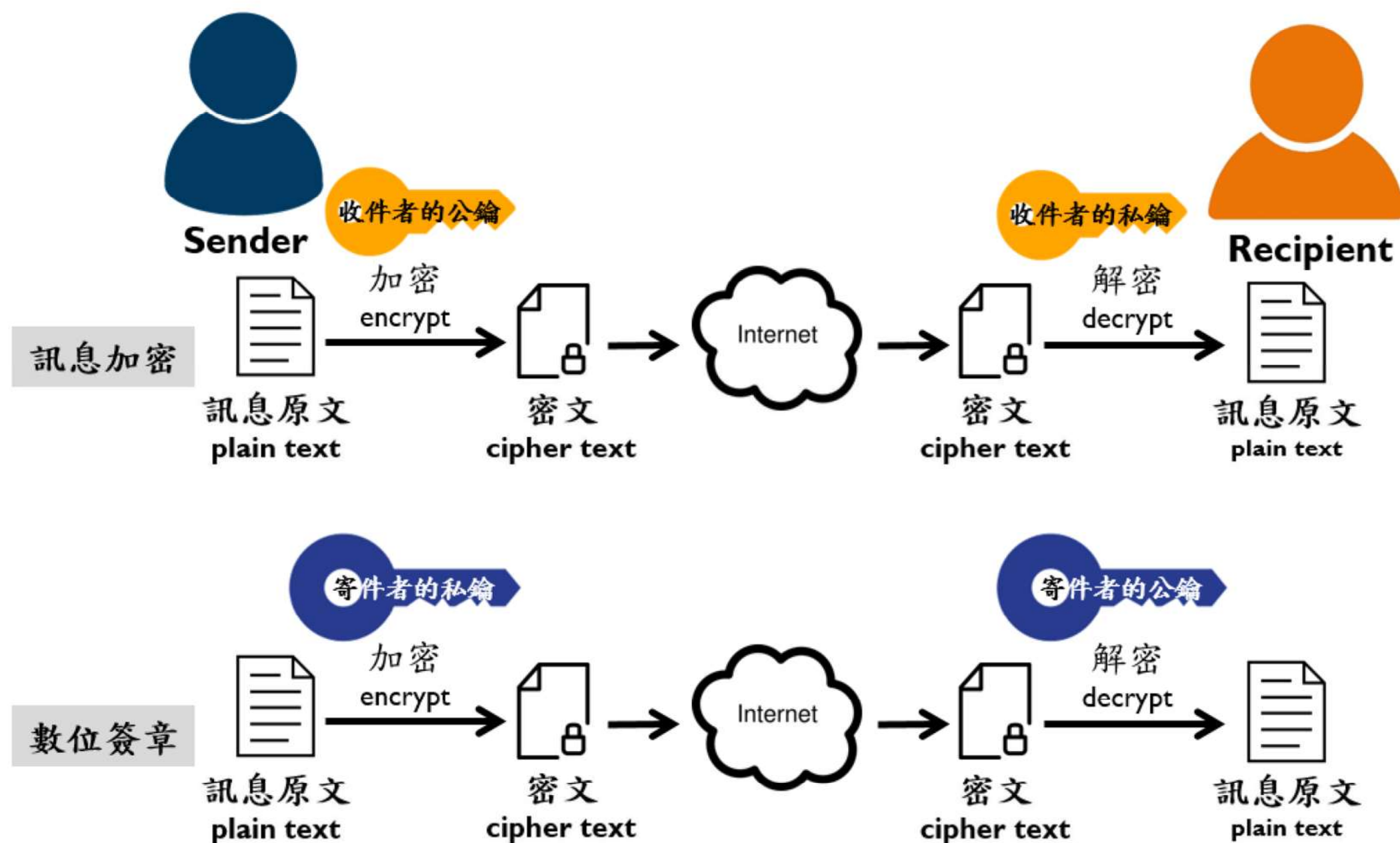
加密技術

◆非對稱金鑰加密技術

- 金鑰對中一個金鑰是公開的，而另一個是保密的。
- 你決定向外發佈的那一半被稱做公開金鑰，另一半保密的是私密金鑰。
- 最初分發哪一半都可以，一旦金鑰對中的一個金鑰已經被分發，則這個金鑰就要保持公有。
- 私密金鑰也必須保持私有，一致性是關鍵。



非對稱金鑰加密技術原理



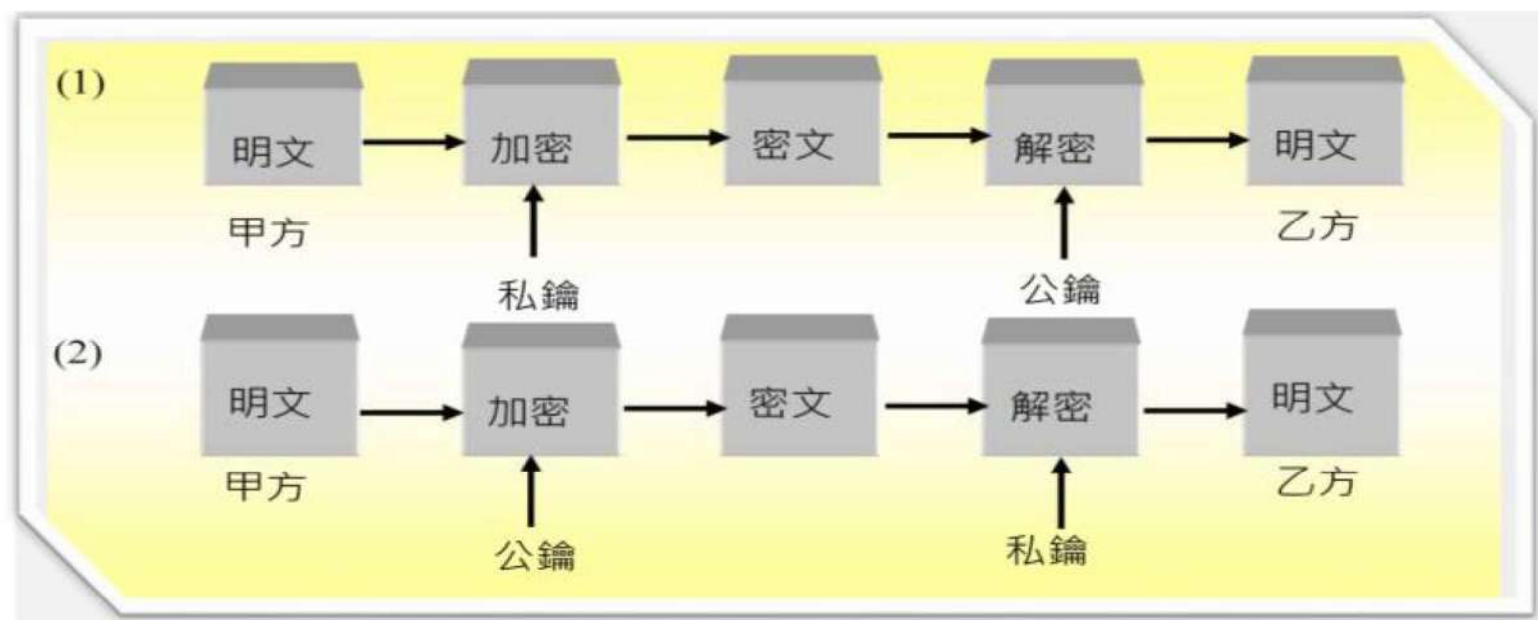
非對稱式的加密法

◆ 非對稱式的加密法：確認發送端的身份

◆ Key1 和 key2 是不相同的，第一種情況中，甲方用自己的私鑰加密，乙方用甲方的公鑰解密，由於只有甲方知道自己的私鑰，所以可確認發送端的身份，問題是公鑰公諸於世，無法確保資料的私密性與完整性。

◆ 非對稱式的加密法：確保資料的私密性

◆ 在第二種情況中，甲方用乙方公佈的金鑰來加密，如此一來，只有乙方有私鑰來解密，這樣可確保資料的私密性，但無法確知發送端是否為甲方。



加密技術的安全性

- ◆ 加密技術的安全性與演算法的強度、金鑰的管理、金鑰的長度，以及亂數產生的不可預測性都有關係。

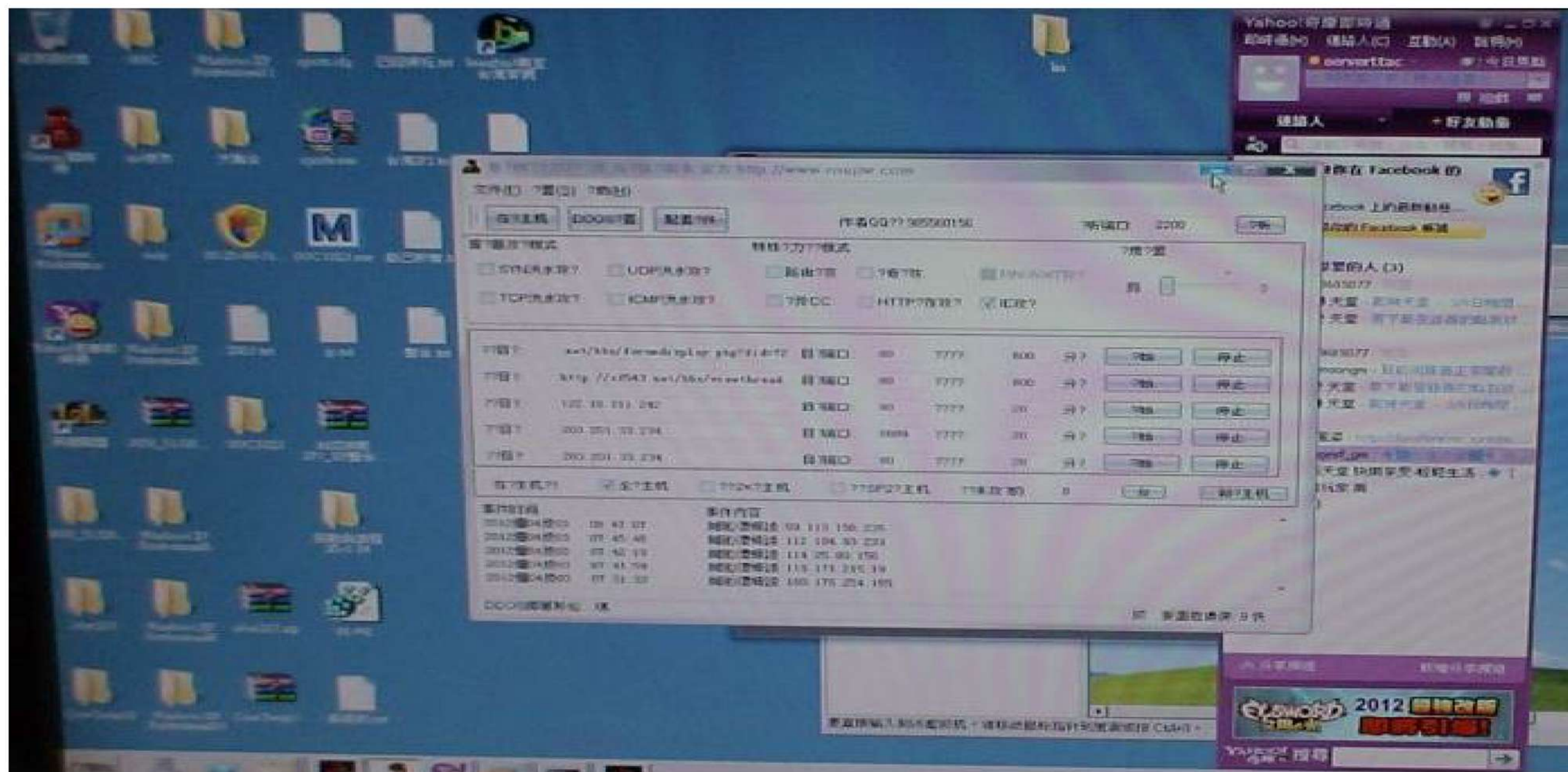
通常演算法是大眾周知的，關鍵在於只要沒有拿到金鑰，必須無法進行解密。

- ◆ 既然演算法是公開的，關鍵就在於金鑰是否容易猜中，只要破解需要很長的時間與很龐大的運算資源就安全。
- ◆ 假如演算法不公開，沒有經過考驗，很難成為真正安全的演算法，很多演算法都曾遭破解。
- ◆ 有金鑰就能進行解密，所以金鑰的保管很重要，可合法使用金鑰的人需要安全的方式取得與保管金鑰。
- ◆ 通常金鑰越長，密文就越難破解，亂數的產生越難被預測，也會使密文越難破解。

DDoS 攻擊程式

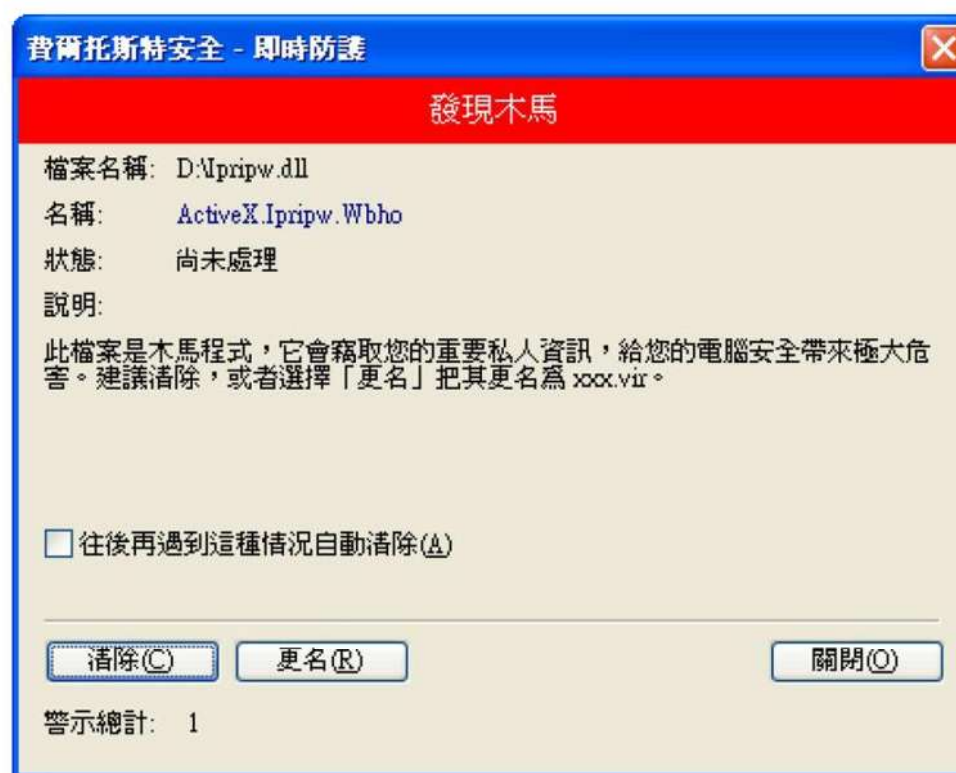
- ◆ 阻斷服務攻擊 (Denial of Service Attack , DoS) 亦稱洪水攻擊，是一種網路攻擊手法，其目的在於使目標電腦的網路或系統資源耗盡，使服務暫時中斷或停止，導致其對目標客戶不可用。
- ◆ 當駭客使用網路上兩個或以上被攻陷的電腦作為「殭屍」向特定的目標發動「阻斷服務」式攻擊時，稱為分散式阻斷服務攻擊 (Distributed Denial of Service attack , 縮寫：DDoS)
- ◆ DDoS 攻擊可以具體分成兩種形式，它們都是透過大量合法或偽造的請求占用大量網路以及器材資源，以達到癱瘓網路以及系統的目的。
 - 頻寬消耗型
 - 及資源消耗型
- ◆ 阻斷服務攻擊的防禦方式通常為入侵檢測，流量過濾和多重驗證，目的在堵塞網路頻寬的流量將被過濾，而正常的流量可正常通過。

DDoS攻擊程式



木馬程式

- ◆ 木馬程式可以自行存在，但不以複製或擴散為目的。
- ◆ 它看似好的程式，卻暗藏惡意。例如一個網路上下載的電玩程式，卻同時在收集系統裡的密碼檔案。
- ◆ 偵測木馬程式有時並不容易，因為它執行起來像是一個正常的應用程式。
- ◆ 不同於病毒或蠕蟲只會產生破壞，木馬程式可能為攻擊者帶來利益，因此木馬攻擊似有凌駕前兩者的趨勢。



木馬 V.S 病毒 V.S 蠕蟲

專業術語	基本介紹	感染	散播	影響
木馬	它本身很獨立，不會進行複製感染，但是會在電腦上進行惡意的行為。	不會	被動	低
病毒	它本身不會主動進行複製感染，基本上會先感染其它檔案，並且允許執行惡意的程式碼，此外只有當檔案被啟動時，才會持續的進行感染。	會	被動	中
蠕蟲	它本身會主動進行複製，主要是透過 Email、即時通訊和 P2P 軟體等方式來進行散播。	不會	主動	高

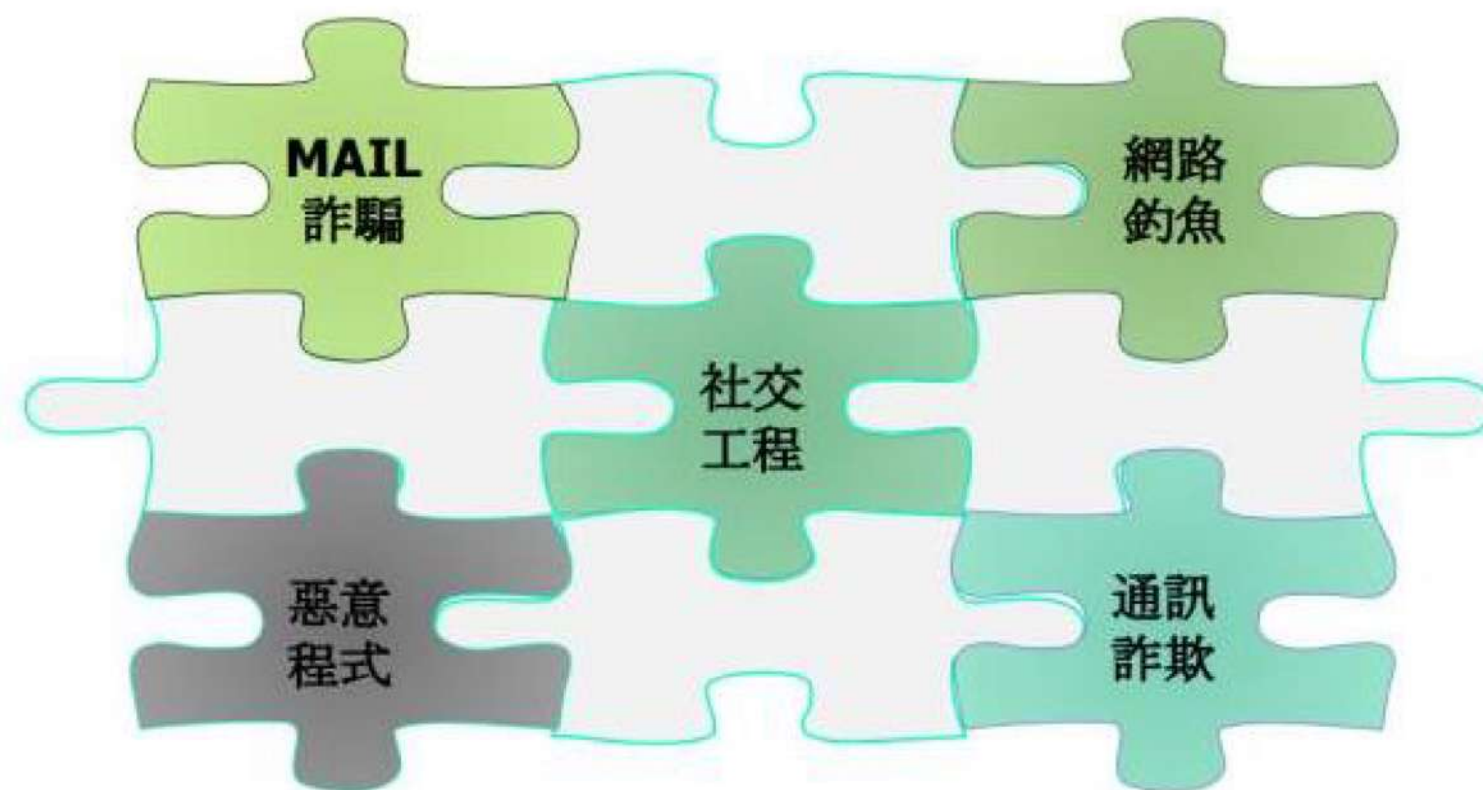
社交工程攻擊之定義

- ◆ 所謂的社交工程(Social Engineering) 是以運用擬真並極具吸引力的方式，來欺騙他人以獲得有用的資訊。
- ◆ 利用人性弱點、人際交往或互動特性所發展出來的一種攻擊方法。
- ◆ 早期社交工程是使用電話或其他非網路方式來詢問個人資料，而目前社交工程大都利用電子郵件或網頁來進行攻擊。

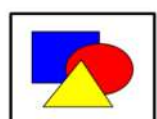
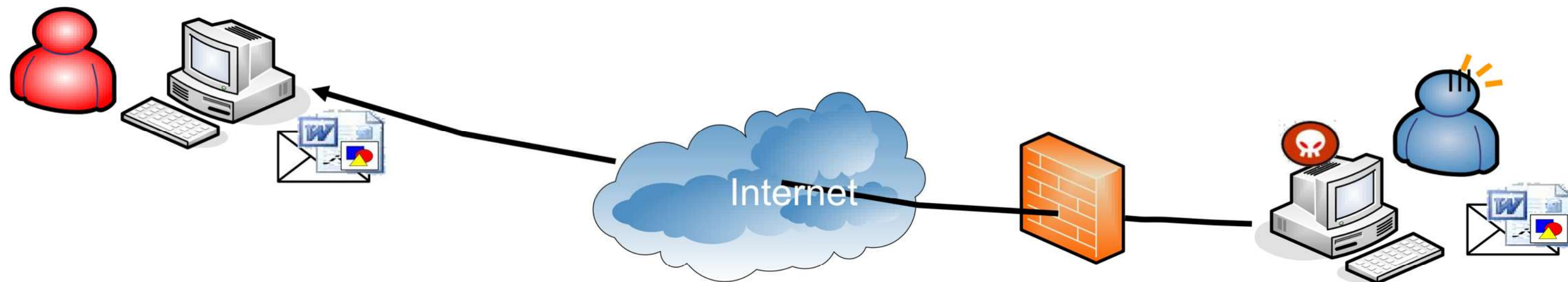
社交工程的各種攻擊方法

- ◆ 透過電子郵件進行社交工程攻擊之常見手法：

- 假冒寄件者
- 使用讓人感興趣的主旨與內文
- 含有惡意程式的附件
- 利用應用程式之弱點(包括零時差攻擊)
- 「設計吸引收件者開啟郵件的主旨」
- 「釣魚郵件」



社交工程攻擊模式



1. 駭客**設計**攻擊陷阱程式(如特殊Word檔案)
2. 將攻擊程式**埋入**電子郵件中
3. 寄發電子郵件給特定的目標
4. 受害者**開啟**電子郵件
5. 啟動駭客設計的陷阱，並被**植入**後門程式
6. 後門程式**逆向連接**，向遠端駭客報到

網路釣魚

- ◆ 網路釣魚(Phishing) 是常見的透過電子郵件手段的一種網路社交工程；藉由誘惑使用者點選網頁連結（利用預覽功能，甚至不必等使用者點選）或打開副加檔案以植入惡意程式（例如：木馬、後門等）。
- ◆ 常見模式為網路詐騙者發送帶有偽冒網站超連結的電子郵件，引誘不知情者前往該山寨版的網站並輸入自己的帳號與密碼，因為山寨版網站的外觀與實際的官方網站十分相像，也讓其有機會剽竊受騙者的帳號密碼。
- ◆ 網路釣魚範例：

- <http://www.paypal.com>
- <http://www.paypa1.com>

真正AWS登入頁面



仿造的網路釣魚郵件



社交工程與網路釣魚之防範

電子郵件防禦社交工程應注意事項

- ◆ 不隨意開啟郵件（注意陌生之寄件者）
- ◆ 取消郵件預覽、不隨意下載附件
- ◆ 確認寄件人與主旨的關係
- ◆ 非經查證，不可直接點選郵件中的超連結
- ◆ 善用密件收件人
- ◆ 不隨意留下郵件地址予他人
- ◆ 定期自我執行病毒與後門程式掃描
- ◆ 了解組織傳送郵件規定
- ◆ 熟悉社交工程的可能手法
- ◆ 通報相關單位

Q&A

事故管理

事件與事故管理

備援與營運持續

資安事件(event) 與資安事故(incident)

- ◆ 系統與網路運作時會產生大量的資安事件，留下的紀錄可用於未來找出相關資安事故的根本原因，以便進行弱點的修補，避免同樣的資安事故再次發生。
- ◆ **資訊安全事件(information security event)**：指被辨識出的可能系統或網路的危害或是防護失敗，一種未知的可能安全問題。
- ◆ **資訊安全事故(information security incident)**：指一個或一連串的未預期的資安事件，極可能造成正常營運與資安的威脅。
- ◆ **兩者的關係**：應該記錄觀察資安事件的變化，未來處理相關的資安事故時可作為判斷的依據或是證據。

法律上應有的認知

- ◆ 資安事故發生勢必會引起風險與損害，衍生出法律上的問題。機構要了解如何在法律上解決資安事故產生的後果。
一般人也要知道該遵循法律，避免因為一些與資訊技術相關的作為觸犯了法律。
- ◆ 政府在西元 2003 年新增刑法第 36 章妨害電腦使用罪，影響電腦機密性、完整性與可用性的行為會受罰。
- ◆ 資安事故的處理強調數位證據，刑事訴訟法特別規範犯罪事實要有證據力的證據才能作為判斷的依據。
- ◆ 個人資料保護法是與資安事故相關的重要法律，機構因業務需要蒐集個資，必須同時負起保護個資的責任。
- ◆ 觸犯法律的資安事故已經有很多實際的案例與判例，雖然數位證據需要技術的支援，已經開始發揮作用。

管理上應有的認知

- ◆ 資安事故的發生與安全管理的關係密切，資安事故處理完以後，應檢討安全管理上的漏洞與問題，避免未來類似的資安事故再度發生。
- ◆ 對於機構來說，為了避免因為資安事故的發生衍生法律上的問題，必須在資訊安全管理上尋找解決方案。
- ◆ 資訊安全管理制度的導入再加上公正機構的驗證，可以確保機構建立符合標準的資訊安全管理制度。
- ◆ ISO27001 是資訊安全管理的標準，BS10012 是個人資料管理的標準，也就是常見的 ISMS 與 PIMS 的驗證。
- ◆ 資訊安全管理制度本身對於資安事故的處理也有一定的規範，導入過程中可嘗試找出最適合機構的方式。

資安事件與事故處理的基本觀念

- ◆ 資訊技術普及加上資訊的流通快速，使資訊環境中的互動大增，這些互動往往有意或無意地造成一些問題。

輕則產生資安事件，嚴重的可以發生資安事故。

- ◆ 資安事故發生的原因

- **內部因素**：因內部人員的操作錯誤、疏忽或是蓄意的進行破壞，使機構的資訊外洩，或是讓駭客以及惡意程式有機可乘，造成機構的損害。
- **外部因素**：駭客發動攻擊，或是惡意程式感染，使機構產生大規模的資訊系統失效、資訊服務暫停，影響正常的運作。

資安事件與事故處理的準備

- ◆ 假如一個機構一直都沒有發生過資安事件或是資安事故，很可能失去對於資安的警覺與認知。

機構應該時時做好處理與因應資安事件及事故的準備，一旦發生時才能從容應變。

- ◆ 當資安事件或事故發生時，應該要有應變處理的計畫，包括相關的政策規定與執执行程序。

- ◆ 資安事件或事故發生時，需要第一線的緊急處理。在發生之前，平時就要注意可疑的現象，必要時須分析。

- ◆ 從得到的資訊內容，可以嘗試判斷發生的是資安事件還是資安事故。

- ◆ 對於蒐集的資料要妥善保存，記錄蒐集的時間與資料的來源，必要時應遵循數位證據保存的標準作業程序。

政府資通安全通報應變的作業

01 整體作業

概觀

訂定組織架構，確認職掌、定義影響等級與作業流程，訂定資安事件發生時的通報應變作業程序

02 通報作業

集結人力

按照組織架構與流程進行通報，必須已先訂定通報作業方式與要求，通報的目的在於啟動應變所需要的人力

03 應變作業

處理問題

應變作業包括事前的安全防護、事中的緊急應變、事後的復原作業，以及應變作業的檢討，事中的緊急應變應考量數位鑑識與數位證據保存

04 資安演練

做好準備

應有專責單位辦理資通安全演練作業，檢測相關單位的資通安全防護與應變能力

政府對於資安事故等級的評估方式

- ◆ 政府對於資安事故等級的評估方式有標準的方法，可供一般機構參考使用，評估出資安事故的影響等級，搭配該等級應採取的處理程序。
- ◆ 資安事故影響等級的評估要依機密性、完整性與可用性，共三個面向進行衝擊性的評估。
- ◆ 由輕到重分成「1」、「2」、「3」、「4」四個等級，最後綜合判斷資安事故的影響等級。
- ◆ 可以建立資安事故影響等級的綜合評估表，區分衝擊的類別以及影響的等級，對照所發生的狀況。
- ◆ 以機密性、完整性與可用性三個面向中衝擊最大的等級，作為整起事故的影響等級。

資安事故處理的目的

- ◆ 確認資安事故是否發生。
- ◆ 降低對業務與網路服務的中斷時間。
- ◆ 提供精準與及時的資訊。
- ◆ 保障由政策與法律要求的權利。
- ◆ 實作控制措施以維護監管鏈。
- ◆ 讓法務組織可對惡意者提起訴訟。



有效的資安事故處理計畫

◆ 定期重新審查計畫文件：

更新人員、科技及業務處理流程。

◆ 訓練：

組織分工與權責、資訊安全技能、危機處理、數位鑑識與調查技能及溝通能力。

◆ 財務支持：

預算、額外的設備、專業人員、員工薪資及訓練費用。

◆ 演練：

定期驗證與修正作業流程。

資安事故處理基本步驟

- ◆ 資安事故發生時應該按照標準的程序進行通報與處理，不能抱著僥倖的心態，或是意圖逃避責任，面對並解決問題才能得到最好的結果。以下是資安事件處理基本步驟：

01 準備

預做準備

準備階段會花很多時間，一般人可能很難接受為還沒發生的事故花費心力準備應變的狀況，但這個階段是必要的過程

02 偵測與分析

識別

偵測的階段也需要花很多時間，嘗試去**識別**可能發展為事故的資安事件，系統在這個階段還是在穩定的狀態

03 封鎖根除與復原

解決問題

緊急封鎖可以防止損害擴大，封鎖以後已經造成服務的中斷，應該盡快排除問題，根除發生的原因，讓系統開始復原

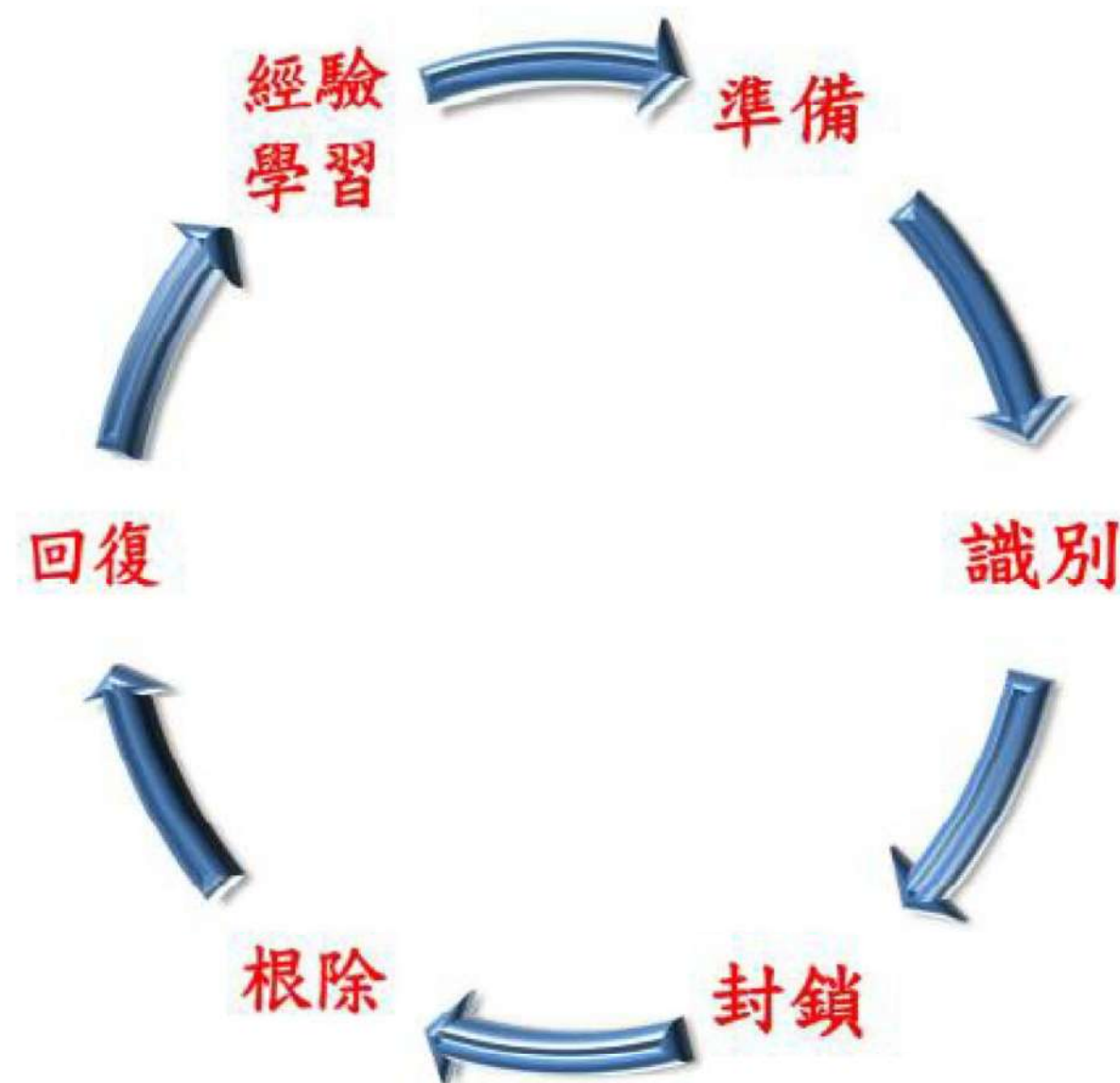
04 事後處置

經驗學習

系統回復之後應該立即開始建立後續處理的報告，讓機構相關成員進行檢討與學習，並規劃補強的措施

資安事故處理步驟 - PICERF

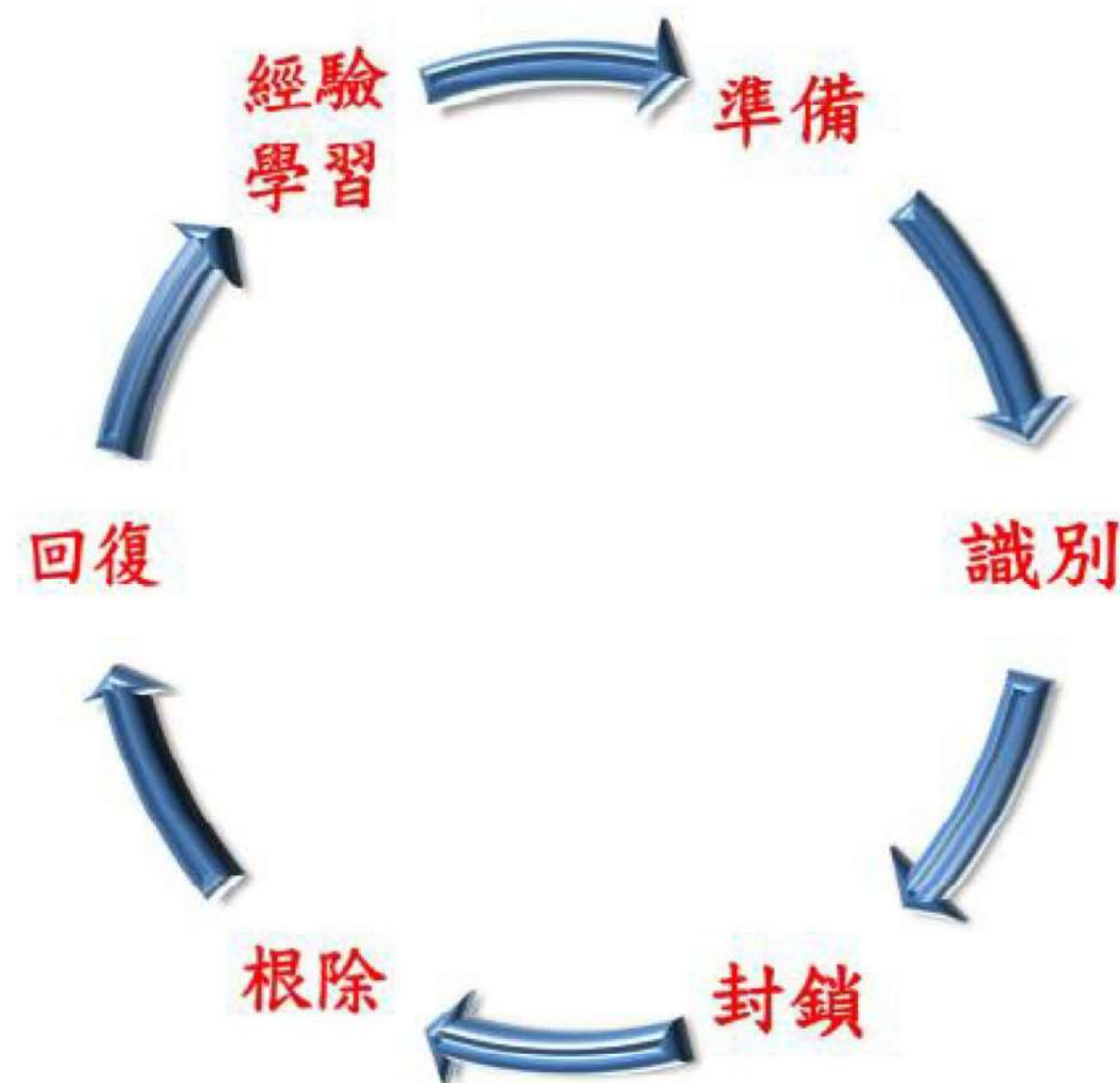
1. **Preparation**：預防準備階段
2. **Identification**：偵測識別階段
3. **Containment**：封鎖圍堵階段
4. **Eradication**：根除階段
5. **Recovery**：回復階段
6. **Follow Up / Lesson Learned**：檢討學習階段



資安事故處理步驟 - 準備階段(Preparation)

◆ 資安事故成功處理的關鍵是事前的「準備」

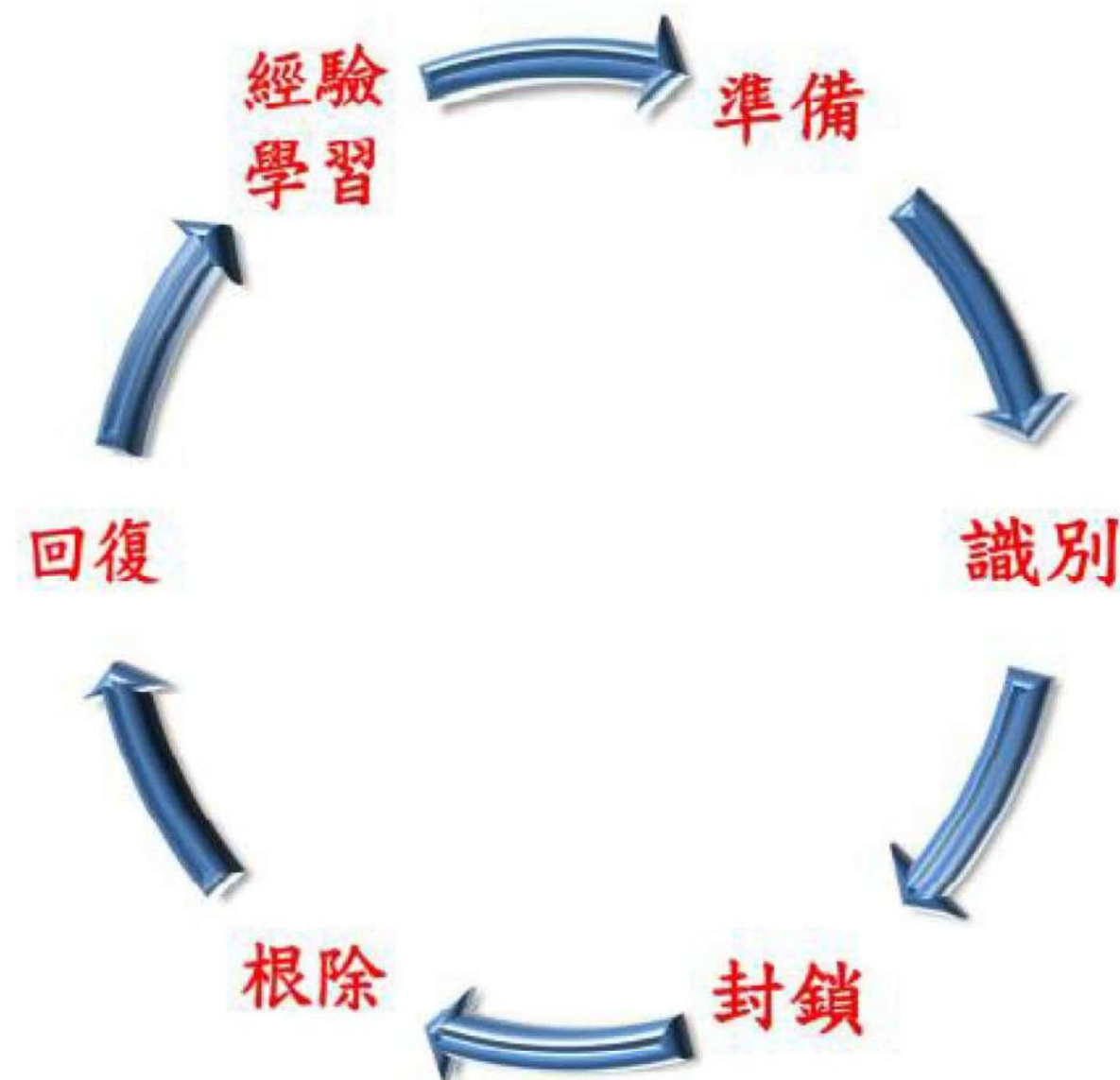
- 組織資安事故處理小組
- 建立資安事故處理策略
- 設計資安事故處理程序
- 建立溝通管道與方式
- 蒐集所需資源
- 練習、練習、再練習



資安事故處理步驟 - 準備階段(Preparation)

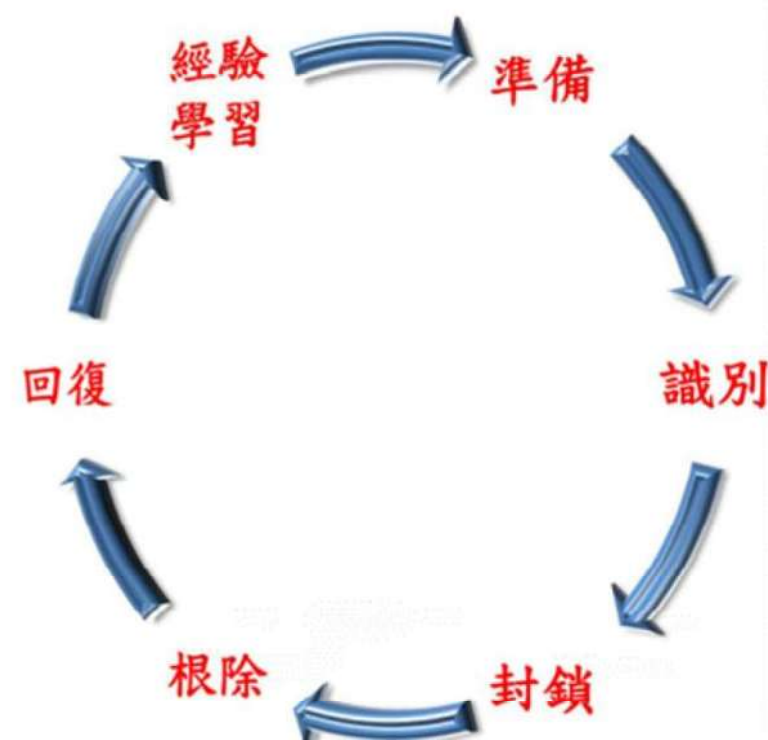
◆ 資安事故處理小組

- 技術部門(IT、資訊安全及系統管理者)
- 管理人員
- 法務部門
- 通訊部門
- 數位鑑識專家
- 公共關係部門
- 人力資源部門
- 實體安全與維護部門



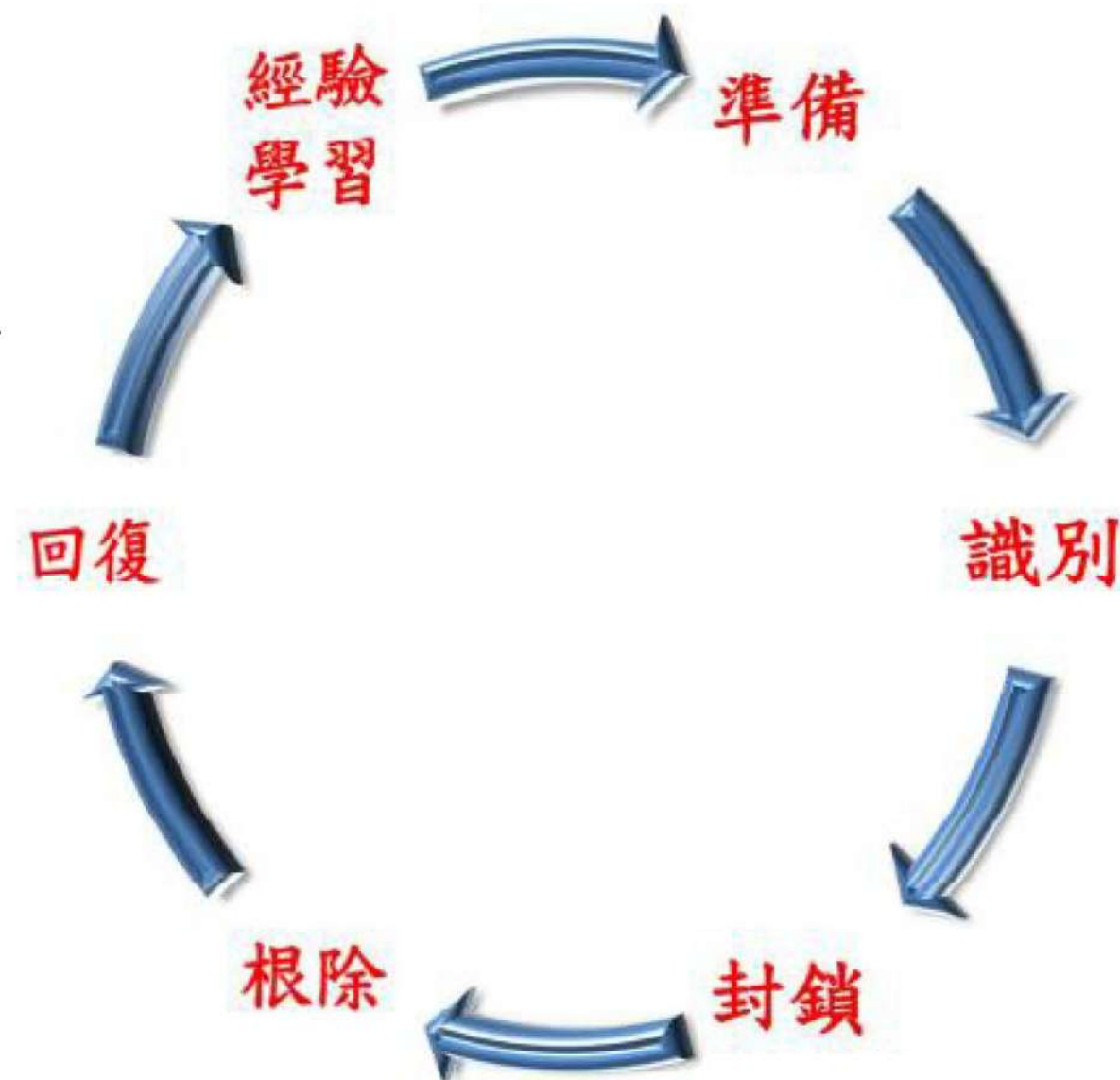
資安事故處理步驟 - 準備階段(Preparation)

- ◆ 機構內處理資安事故的團隊要在這個階段做好進行資安事故處理的準備，包括確認應變小組的成員，備齊聯絡的清單，以及可能需要的設備與物品
- **做好人員編組的準備**：資安事故需要人力來處理，有時候不同類型的資安事件會需要不同類型的人員處理。
- **清楚的聯絡資訊**：要找對人才能順利解決問題，當事故發生時必須盡快取得相關人員或廠商的聯絡資訊。
- **備好需要的工具**：處理資安事故時可能會用到一些工具與設備，例如安全的儲存空間、相關的軟硬體。



資安事故處理步驟 - 識別(Identification)

- ◆ 資安事故無法完全防制，但必須被偵測。
- ◆ 識別意圖(故意或無意)。
- ◆ 確認範圍：識別哪些系統、人員及資訊資產被包含在處理的資安事故中。
- ◆ 保留證據：保護資安事故的事實。
- ◆ 可疑的事故
 - 新增帳號、新建檔案及檔案的修改。
 - 入侵偵測系統觸發的事件與防火牆存取紀錄。
 - 效能變差、服務無回應及系統不穩定。
- ◆ 監聽正在進行的攻擊行為
 - 透過網路封包的蒐集。



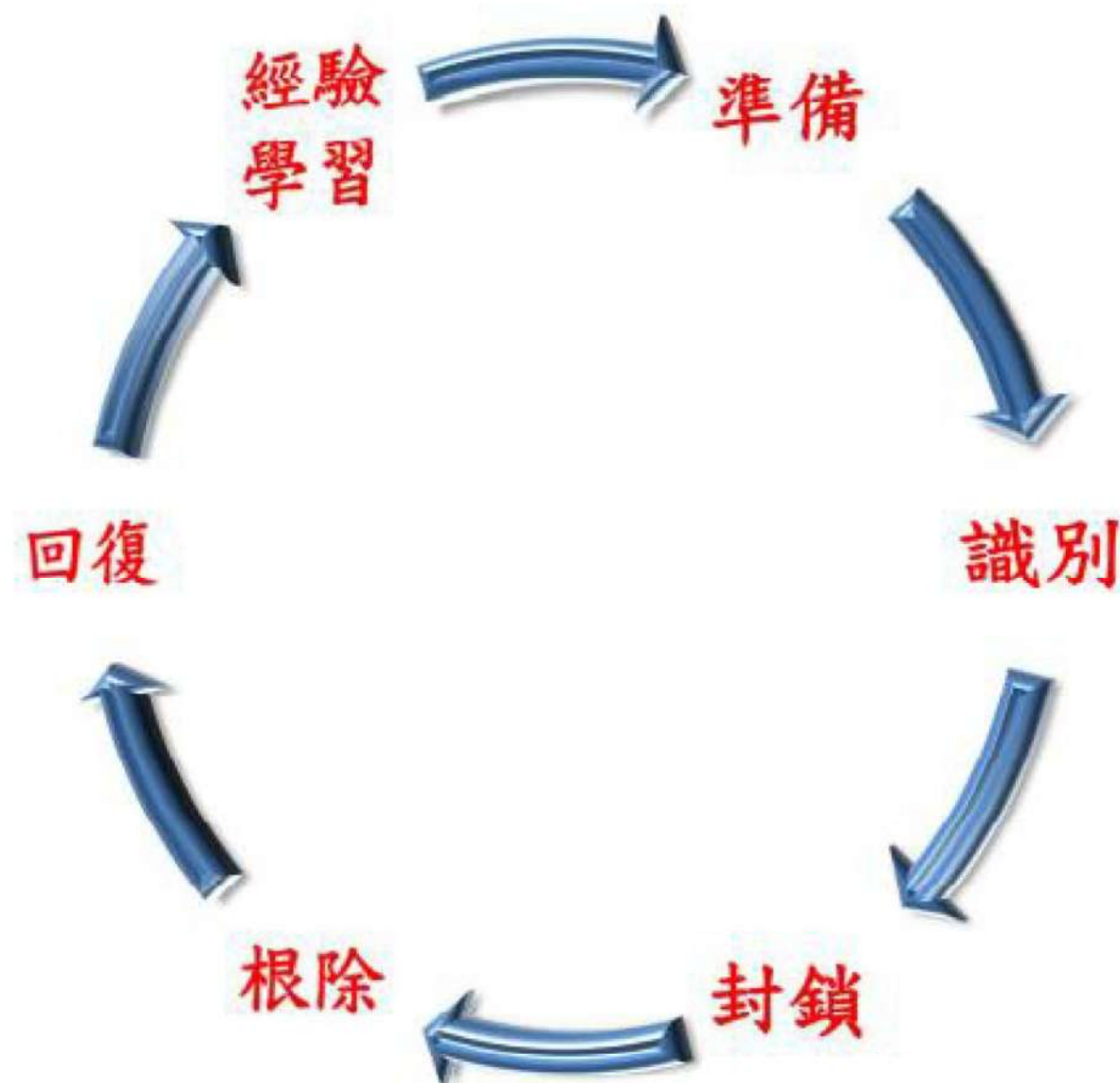
資安事故處理步驟 - 識別(Identification)

◆ 數位證據的取得

- 採用被接受的磁碟映像複製工具(所有磁區的複製，配合雜湊函數以檢驗被複製出來的資料沒有被竄改)。
- 配合錄影機記錄螢幕顯示的內容與採證過程。

◆ 識別出來的相關證物從發現到提出至法院必須有完整明確的監管紀錄

- 每一項證據必須由可證明身分的人員所保管。
- 當保管人交接時必須被記錄。
- 在儲存體中的證物必須被保護，以免被污染或變更。

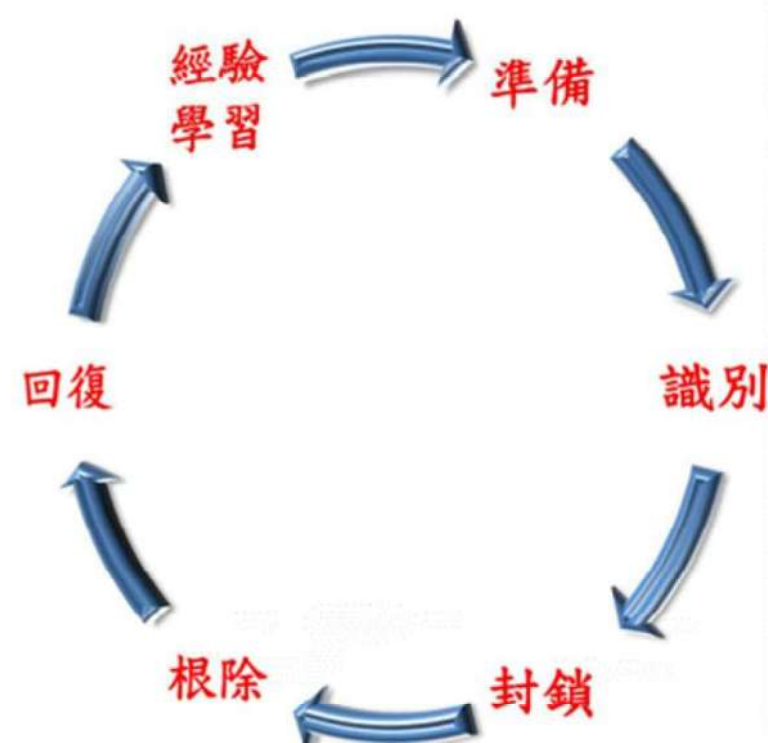


資安事故處理步驟 - 識別(Identification)

◆ 偵測到異常狀況以後，必須判斷屬於一般的資安事件還是風險較高的資安事故，進行事故的識別。

了解是在哪一個環節被入侵，最後要評估影響的範圍以及可能造成的損害。

- **善用工具**：防火牆或是入侵偵測等工具都能自動對可疑事件進行回報，彌補人為監控的不足
- **正確的分析與判斷**：事故處理時對於系統的運作勢必會造成影響，應避免誤判造成非必要的服務停止
- **損害的評估**：了解受影響的範圍，被運用的弱點是否仍然存在，是否受遠端操控

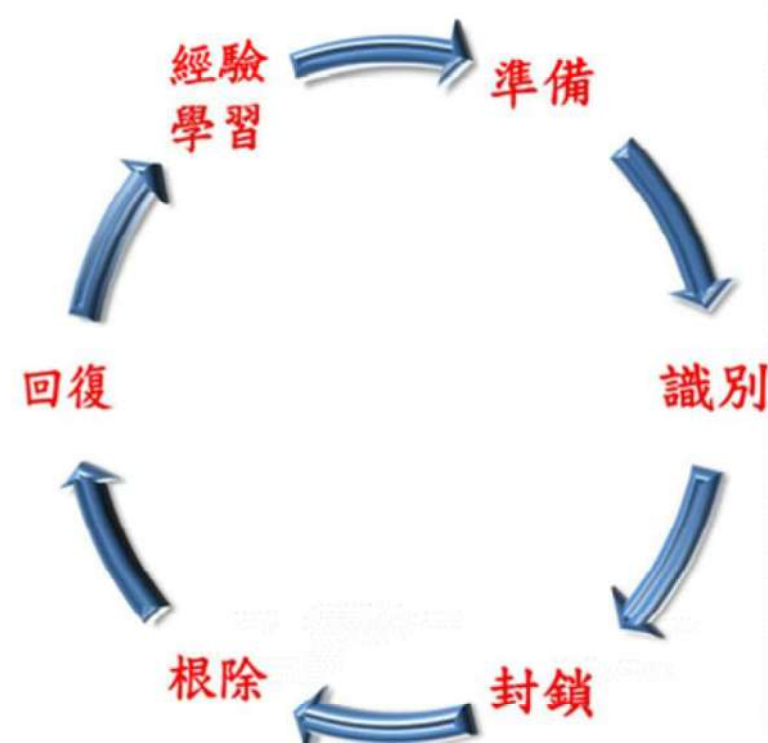


資安事故處理步驟 - 識別(Identification)

◆ 事故的識別，一般的入侵都會從最外層的網路開始，經過主機，再到達系統的層次。

所以事故的識別可以從網路端、主機端與系統的層次來進行防護偵測。

- **系統防護偵測**：監視主機的行為，運用防毒軟體或是端點安全檢測軟體進行系統的防護偵測。
- **主機端防護偵測**：監視主機對外的通訊與進出的資料，運用本地端防火牆與主機的入侵偵測系統。
- **網路端防護偵測**：透過網路上發現的徵兆進行識別，可運用防火牆、網路型的 IDS、IPS 與 DMZ 系統等。

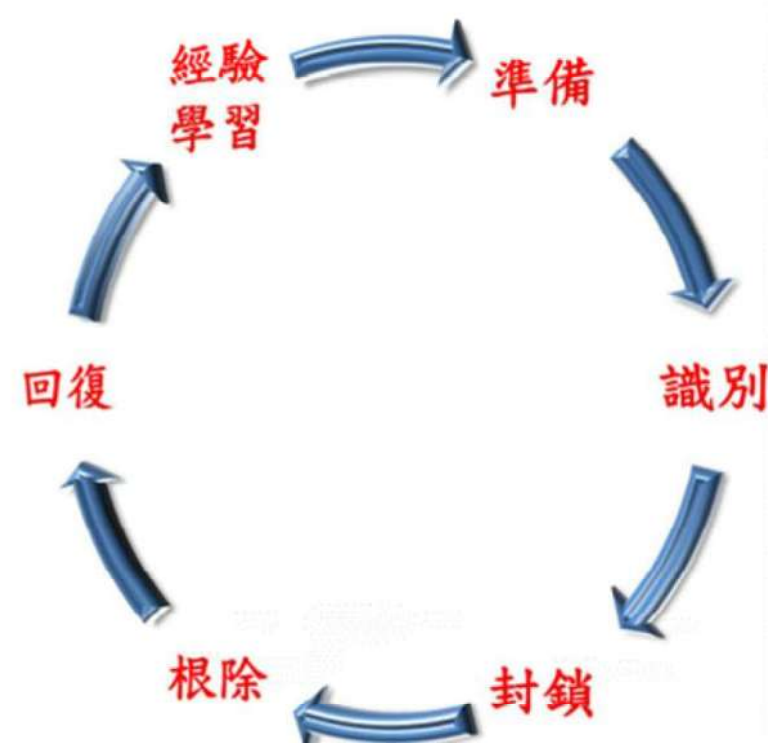


資安事故處理步驟 - 封鎖、根除與復原階段

◆ 這個階段可分成封鎖、根除與復原一共三個階段，從上一個階段取得的資訊會有幫助。

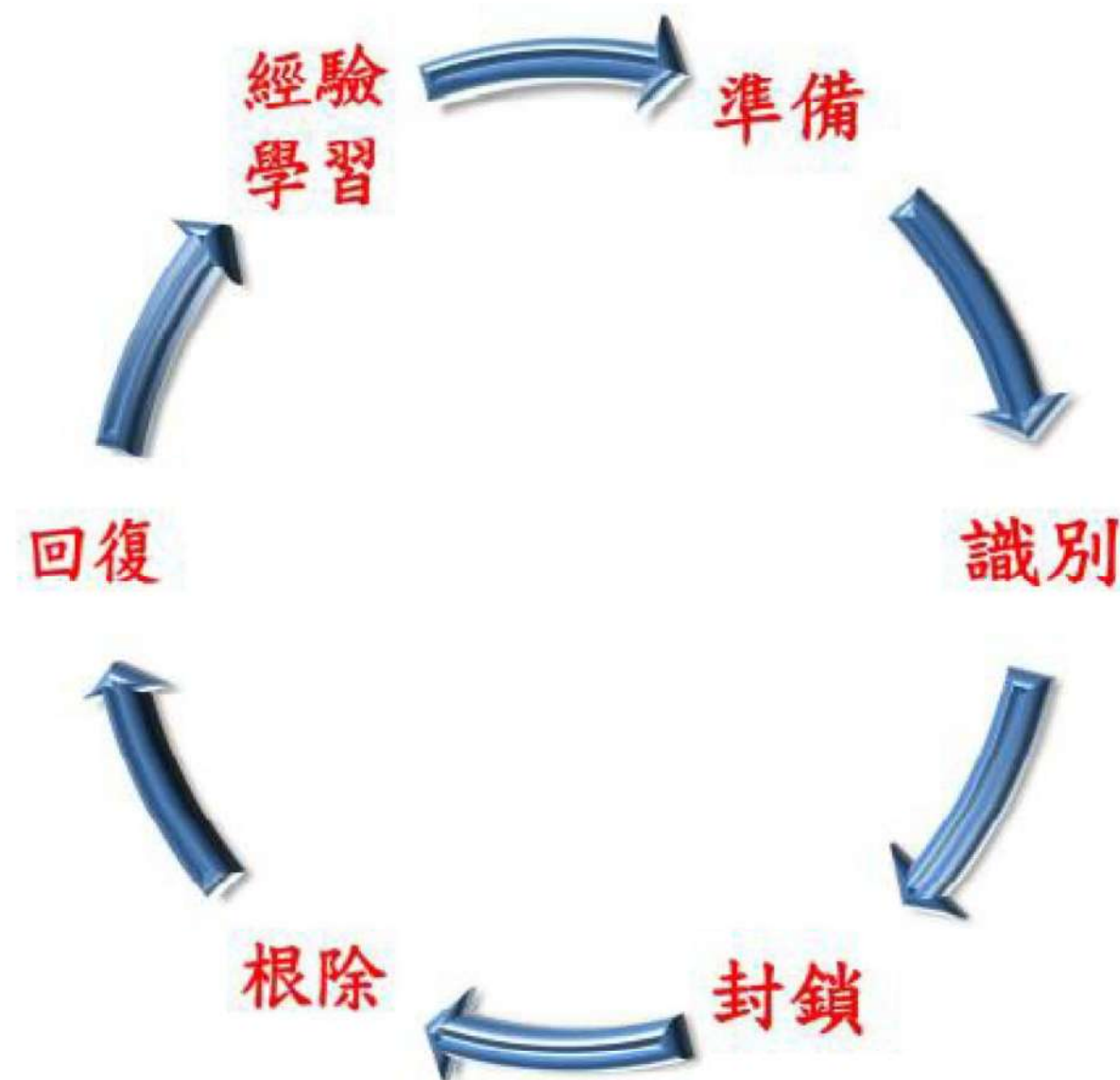
除了要移除感染源之外，還要加強系統的防護，才能夠抵禦類似的攻擊。

- **封鎖(containment)**：避免影響擴大，防止入侵的行為持續，可採取短期或是長期的封鎖措施。
- **根除(eradication)**：當事故的發展被掌控以後，可嘗試找出根因，移除與攻擊相關的因素，例如惡意程式。
- **復原(recovery)**：讓被攻擊的系統恢復正常運作，要有完整的測試計畫，確認正常，並進行監控觀察。



資安事故處理步驟 - 封鎖(Containment)

- ◆ 當資安事故已被識別且相關證物監管鏈已被建立後，接下來就開始「封鎖」入侵來源，以避免災害擴大。
- ◆ 識別可信任來源：不只是來源網路地址或設備，也包含使用者避免驚動入侵者以避免證據被銷毀。
- ◆ 開始進行證據分析與數位鑑識。
- ◆ 減緩攻擊的封鎖行動：
 - 變更通行碼與權限
 - 變更主機名稱與IP位址
 - 將可疑的流量導到不存在的位址
 - 阻擋攻擊來源IP或網段
 - 在類似系統上更新修補程式
 - 關閉服務



資安事故處理步驟 - 根除(Eradication)

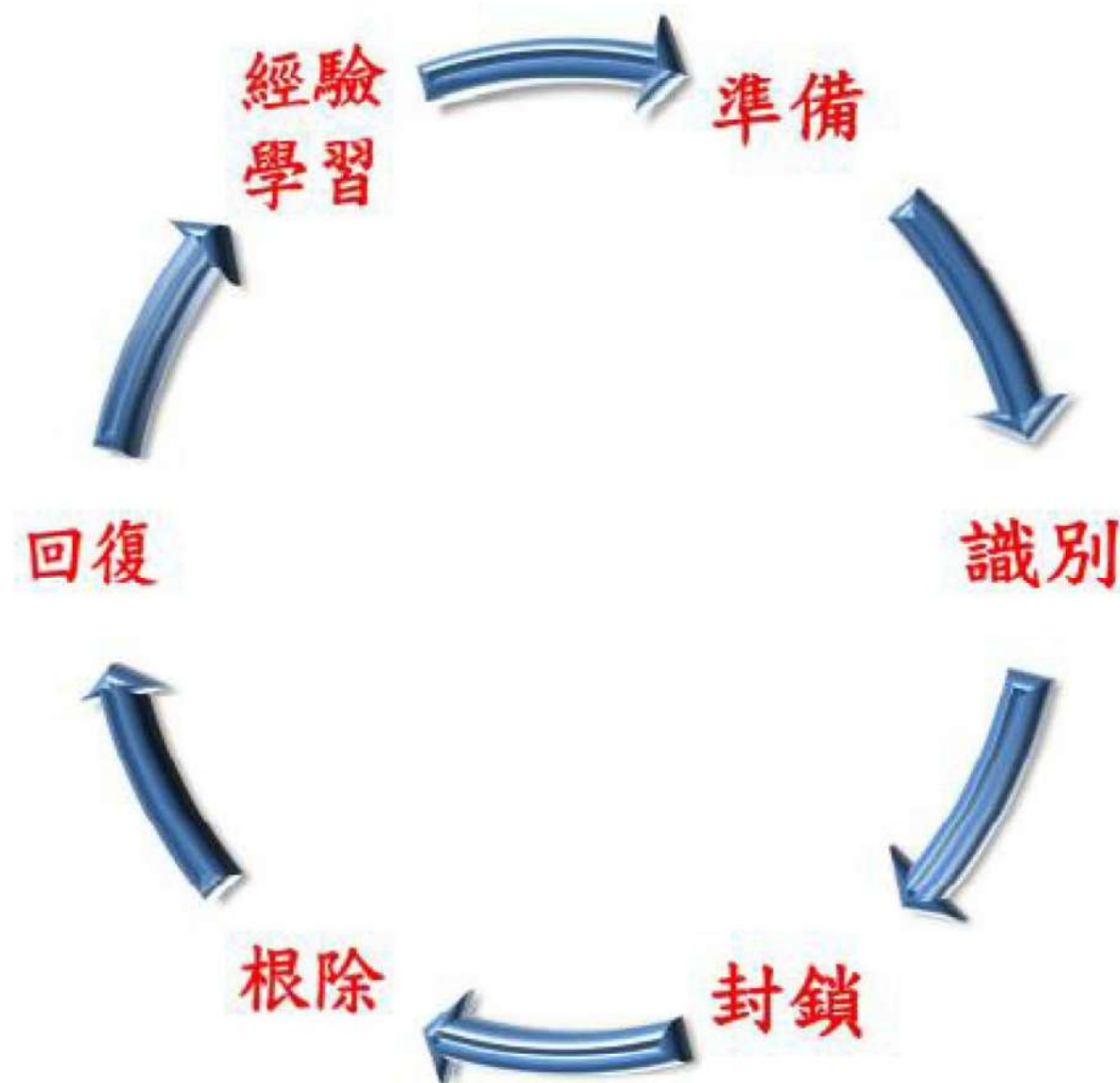
◆ 一旦資安事故已被控制，接下來要從系統或網路中完全移除惡意程式。

◆ 決定採用移除或回存方式：

- 是否可以完全移除乾淨
- 備份資料中可能就存有惡意程式

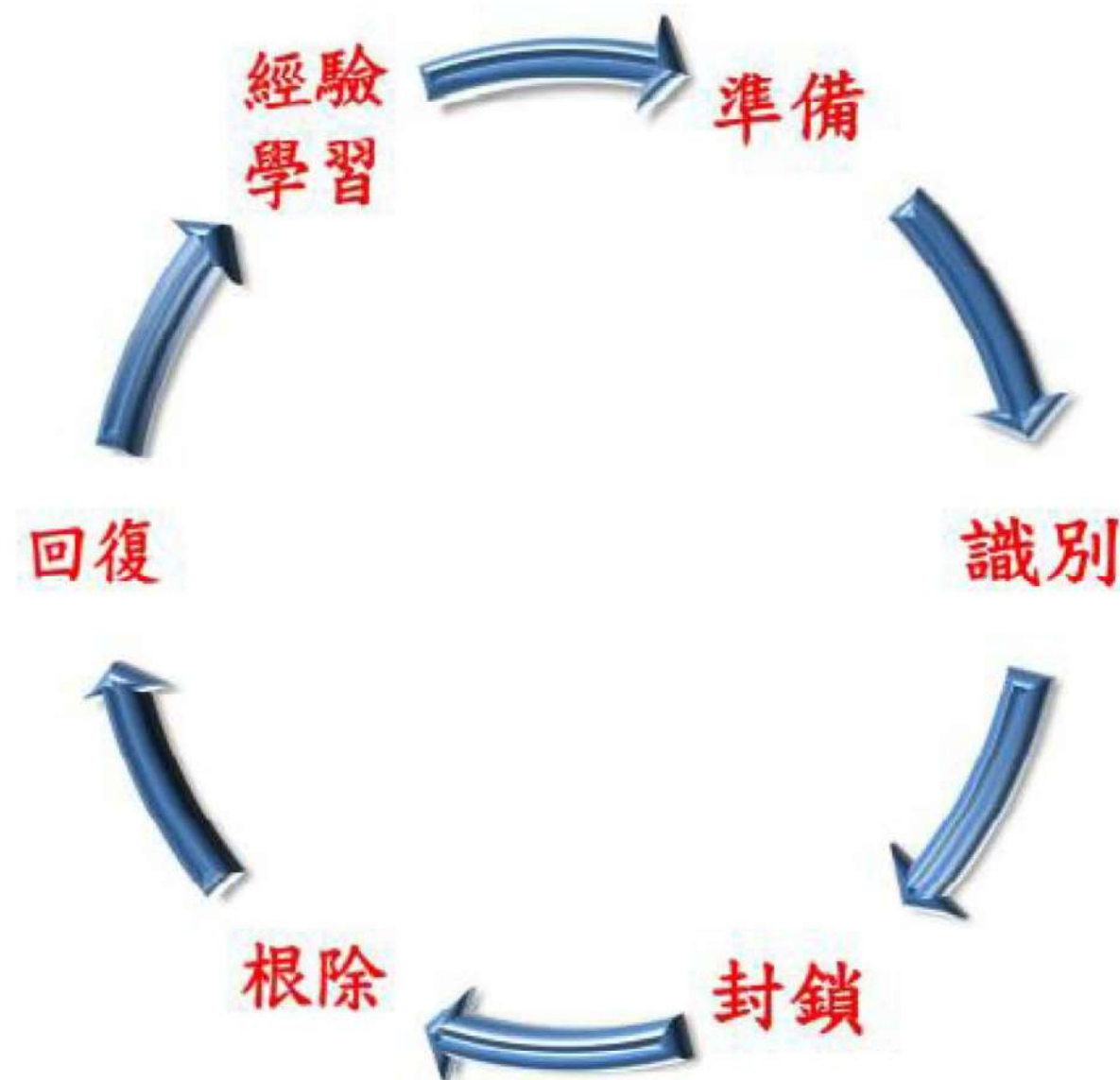
◆ 強化防禦機制：

- 建立額外的偵測與防禦方法
- 提升稽核紀錄的詳細程度
- 在其他系統中尋找已發現的惡意程式
- 更嚴謹控管存取來源



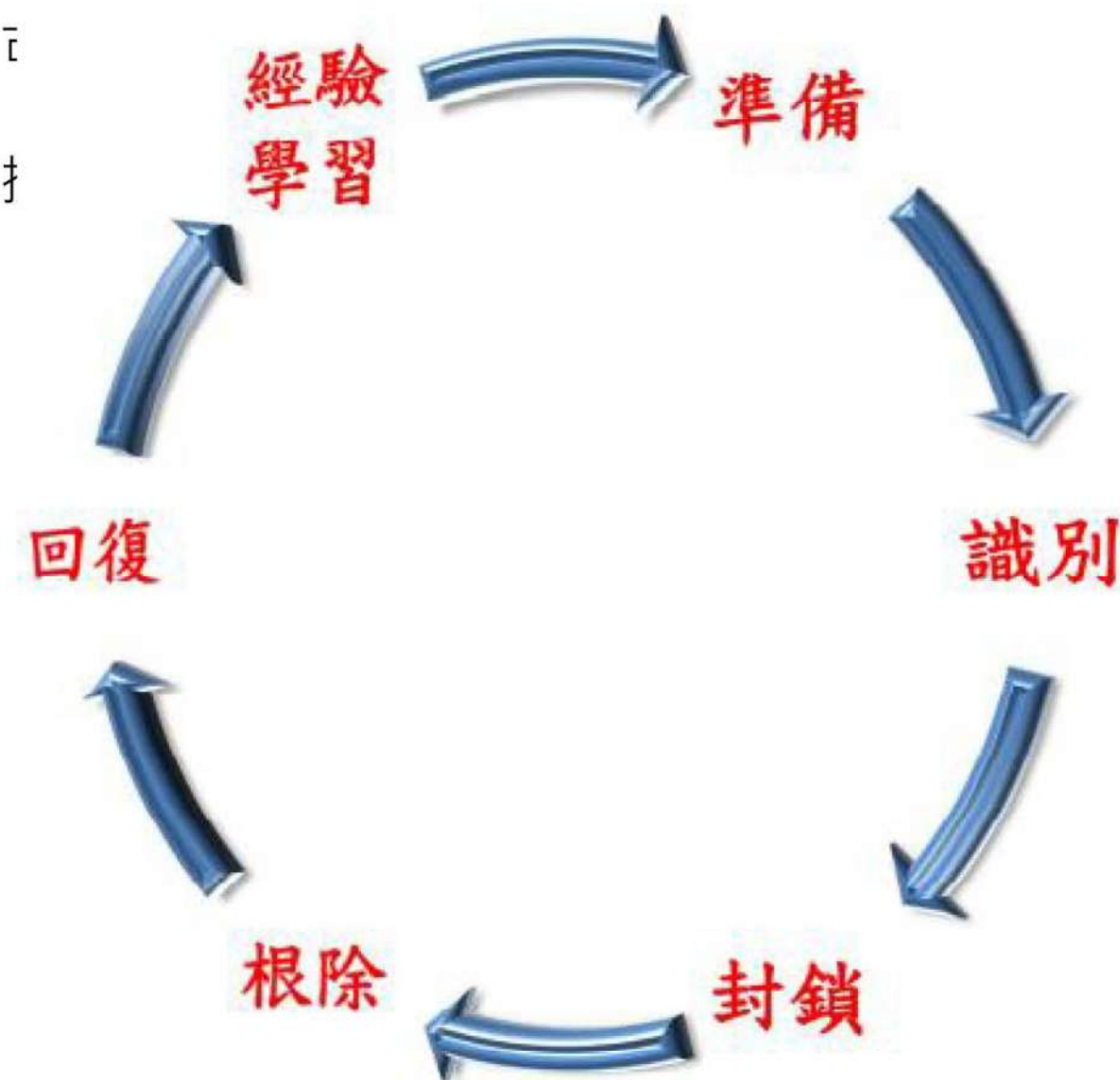
資安事故處理步驟 - 復原(Recovery)

- ◆ 一旦威脅被根除，接下來應開始將業務與服務回復至正常運作狀態。
- ◆ 加強監控以偵測攻擊是否再發生：
 - 客製化入侵偵測規則。
 - 在網路、主機及應用程式中，實作額外更詳細的稽核紀錄。



資安事故處理步驟 - 事後處置階段

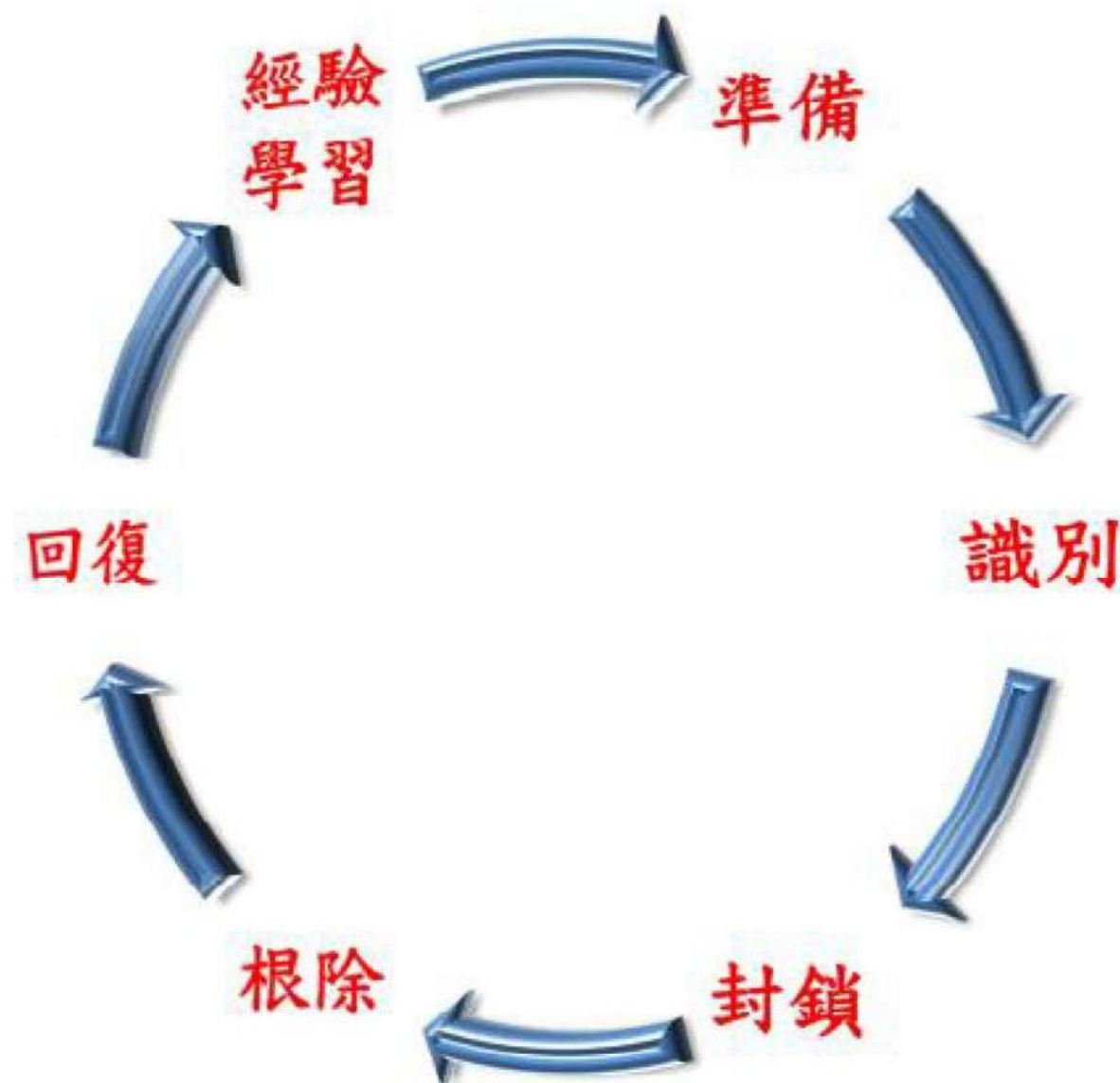
- ◆ 對於處理的過程應保留完整的紀錄，事後才能清楚看到進行了哪些工作，
牽涉到法律與求償的部分，可能需要依照原本訂定的資安事故處理的程序



資安事故處理步驟 - 經驗學習(Follow Up/Lesson Learned)

◆ 召開經驗學習會議

- 在相關處理人員記憶猶新的情況下，讓組織在資安事故中學習防護經驗。
- 建議修改相關政策或程序，以利未來安全防護機制實作時可避免重蹈覆轍。



營運持續

業務持續運作計畫之目的

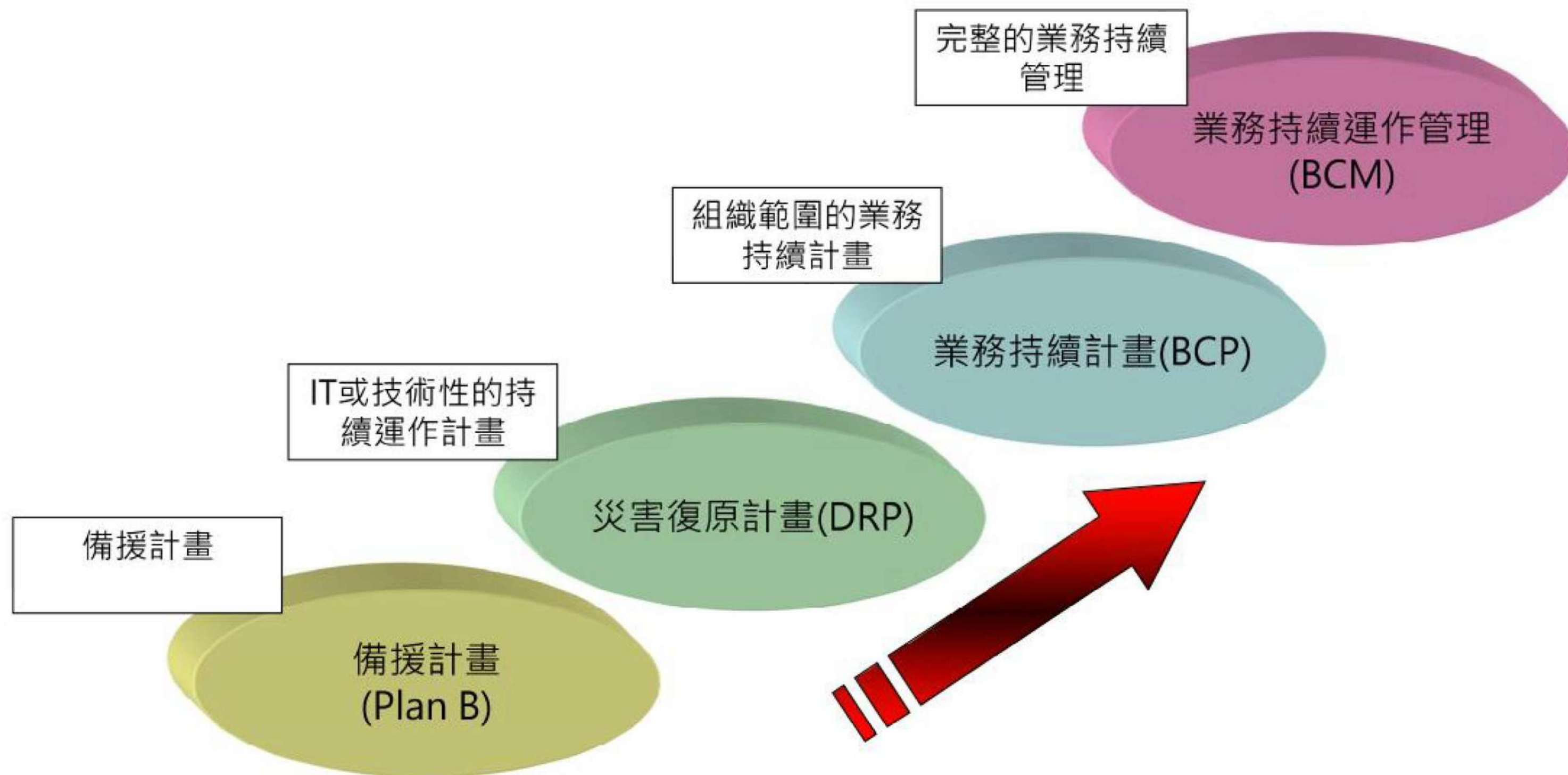
營運持續管理之目標主要有以下幾項：

- ◆ 防止業務活動中斷，確保重要關鍵業務流程不受重大故障與災難的影響。
- ◆ 結合預防與復原措施，將風險造成的影響降低到可以接受的等級。
- ◆ 分析災難、安全缺失及服務損失的後果。制定與實施應變計畫，確保在要求的時間內恢復業務流程。
- ◆ 選用控制措施降低風險，限制破壞性事件造成的後果，確保重要作業能及時復原。

天災人禍、意外，風險無所不在，未雨綢繆，有備無患



業務持續管理的發展沿革



營運持續管理的分類

營運持續計畫（BCP）

負責在遭到破壞或系統中斷後支持組織的業務功能。

業務復原計畫（BRP）

負責緊急事件發生後，業務處理的復原。

災難復原計畫（DRP）

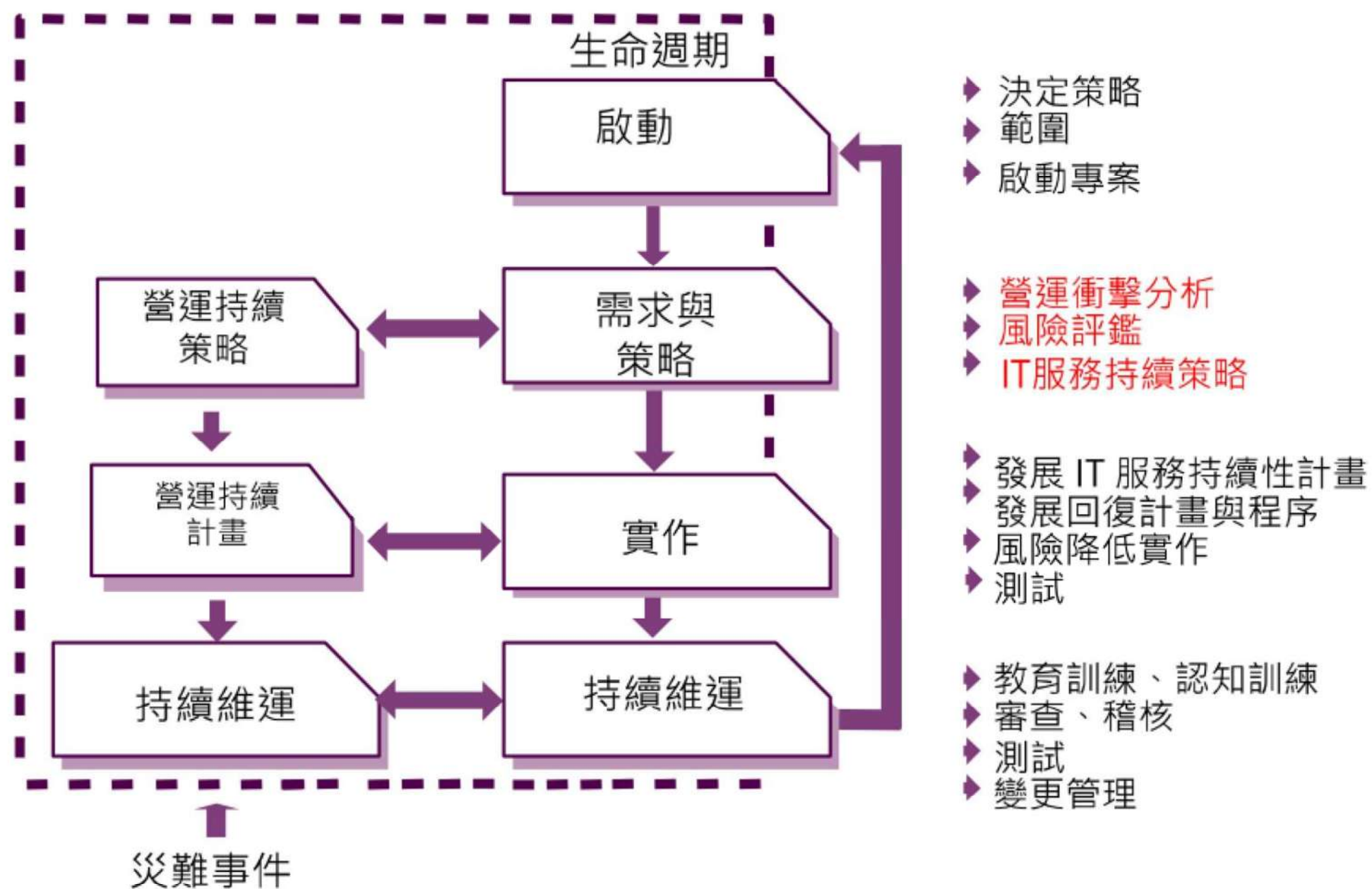
用於災難事件，在一段時間內對正常設備不能使用的情況下，在異地復原目標系統或IT設備的運轉。

異常事件回應計畫（IRP）

一套針對組織IT系統網路攻擊的處理過程，通常包括對惡意事件的識別、規避和恢復。

營運持續管理生命週期

營運持續管理生命週期



CNS27001 對營運持續管理之要求



業務持續運作的需求

◆法律與規範的要求

◆定義範圍

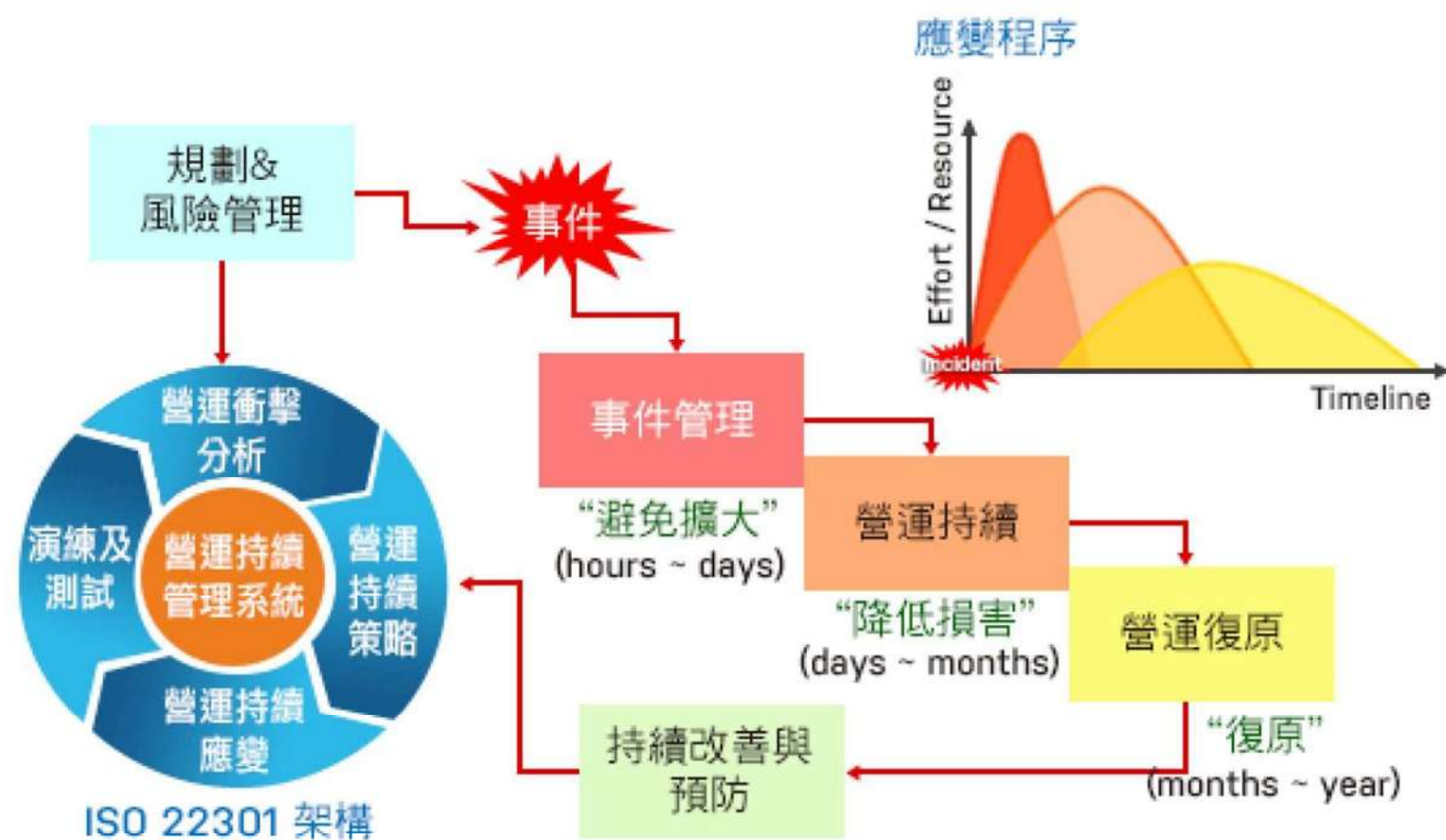
- BCP 需要處理的災害類型：天災與人禍
- 全部、特定區域及特定業務

◆參與角色

- 計畫主要負責人
- 各部門主管與高階管理人
- IT 部門、安全部門及通訊部門
- 法務部門
- 當災害發生時需要執行 BCP 計畫的部門都應參與 BCP 的發展

營運衝擊分析 - BIA

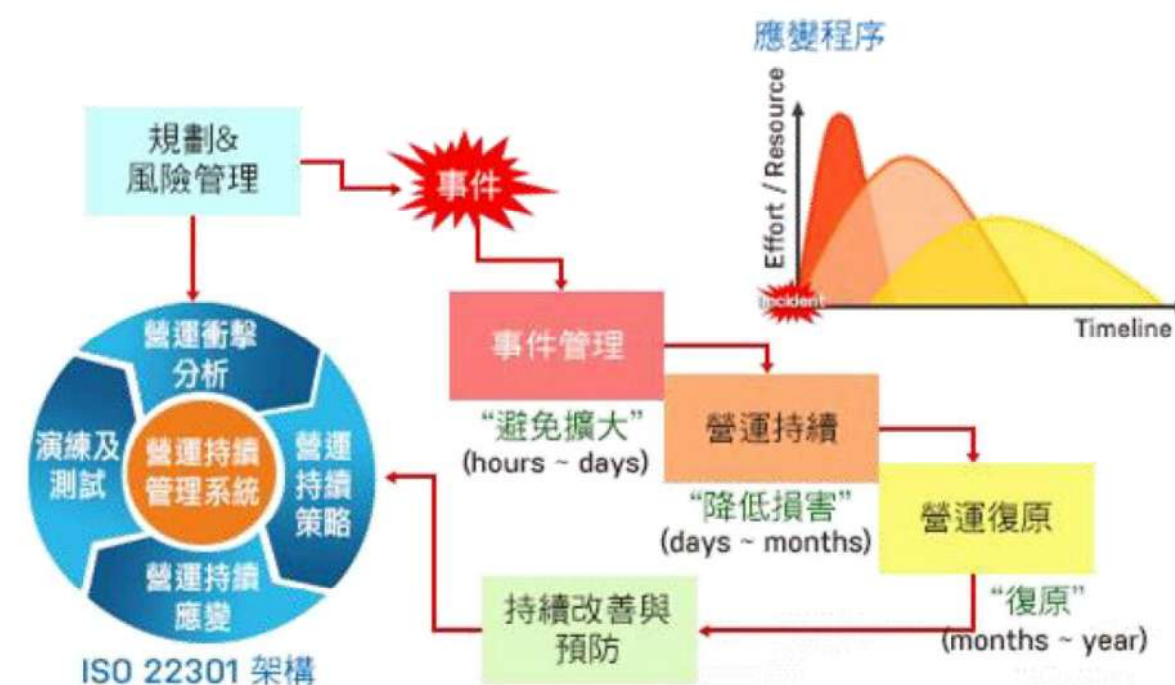
- ◆ 營運衝擊分析，Business Impact Analysis，簡稱 BIA，是在衡量意外災難如果發生，它對系統的破壞會造成組織多大的損失。用來瞭解當災害發生後的嚴重程度，
- ◆ 可以用定量化或定性化的方法進行分析。
- ◆ 徵詢管理至使用者階層對資源的使用需求，來判別其依賴程度和重要性。



營運衝擊分析 - BIA

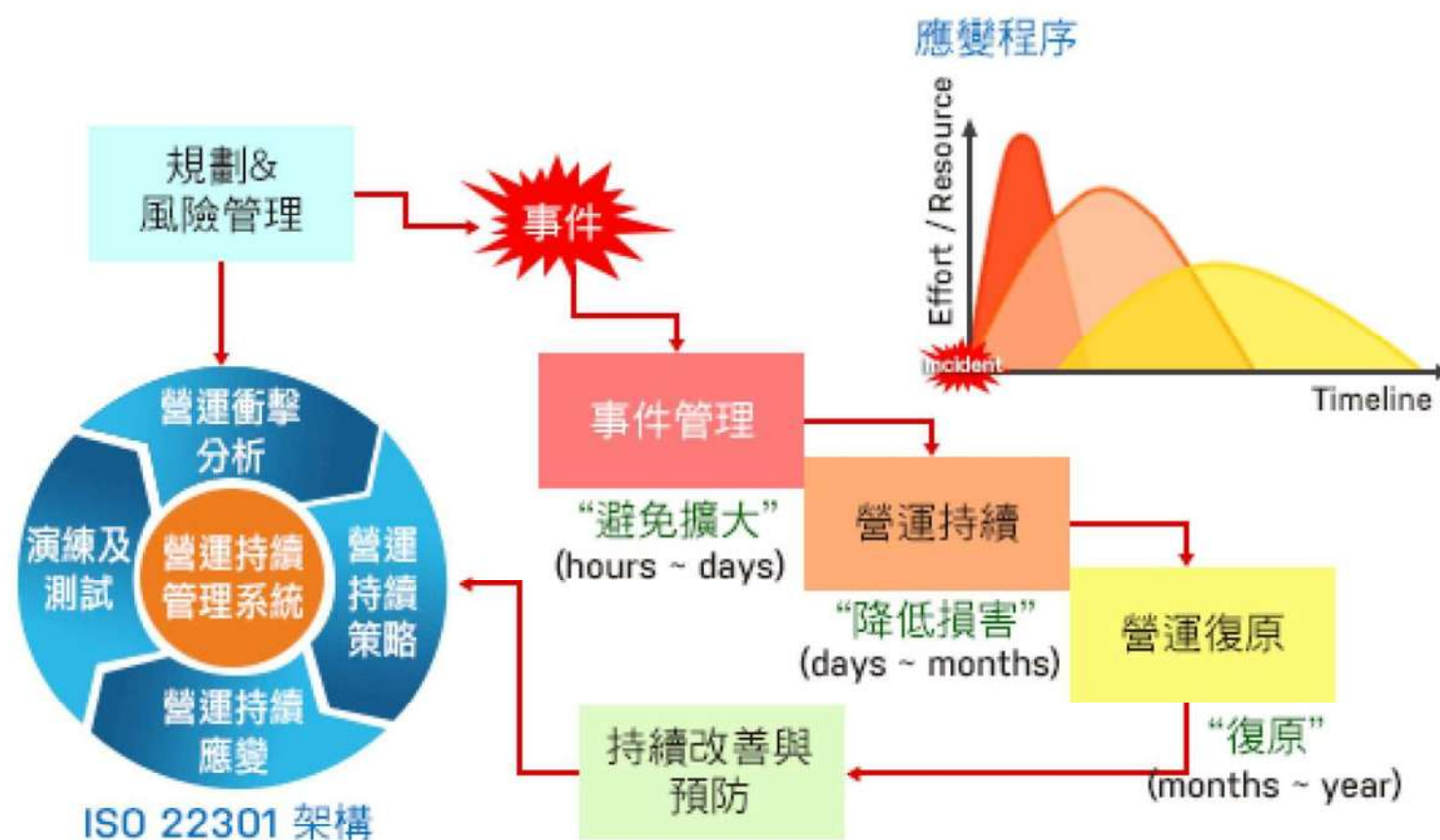
◆ 營運衝擊分析步驟

- 識別組織的關鍵業務功能
- 計算關鍵業務
- 最大可承受中斷時間(MaxTolerablePeriodofDisruption, MTPD)
- 目標回覆時間(RecoveryTimeObjective, RTO)
- 各營運活動可容忍資料遺失之期間(RecoveryPointObjective, RPO)
- 最低服務水準(Minservicelevel)



營運衝擊分析目的

- ◆ 依照重要程度來定義不同作業程序的重要次序。
- ◆ 定義各系統的最大可容忍停機時間，又稱為目標修復時間。
- ◆ 在組織內形成營運持續的資安共識。
- ◆ 提供管理階層在訂定業務持續性策略和購置支援設備時的參考資料。



風險評鑑

◆ 識別：所有會造成中斷大於「MTPD(關鍵業務之最大可容忍中斷時間)」的事件。

◆ 例子：

➤ 台電大斷電

➤ 水災

➤ 地震

➤ 機房大火



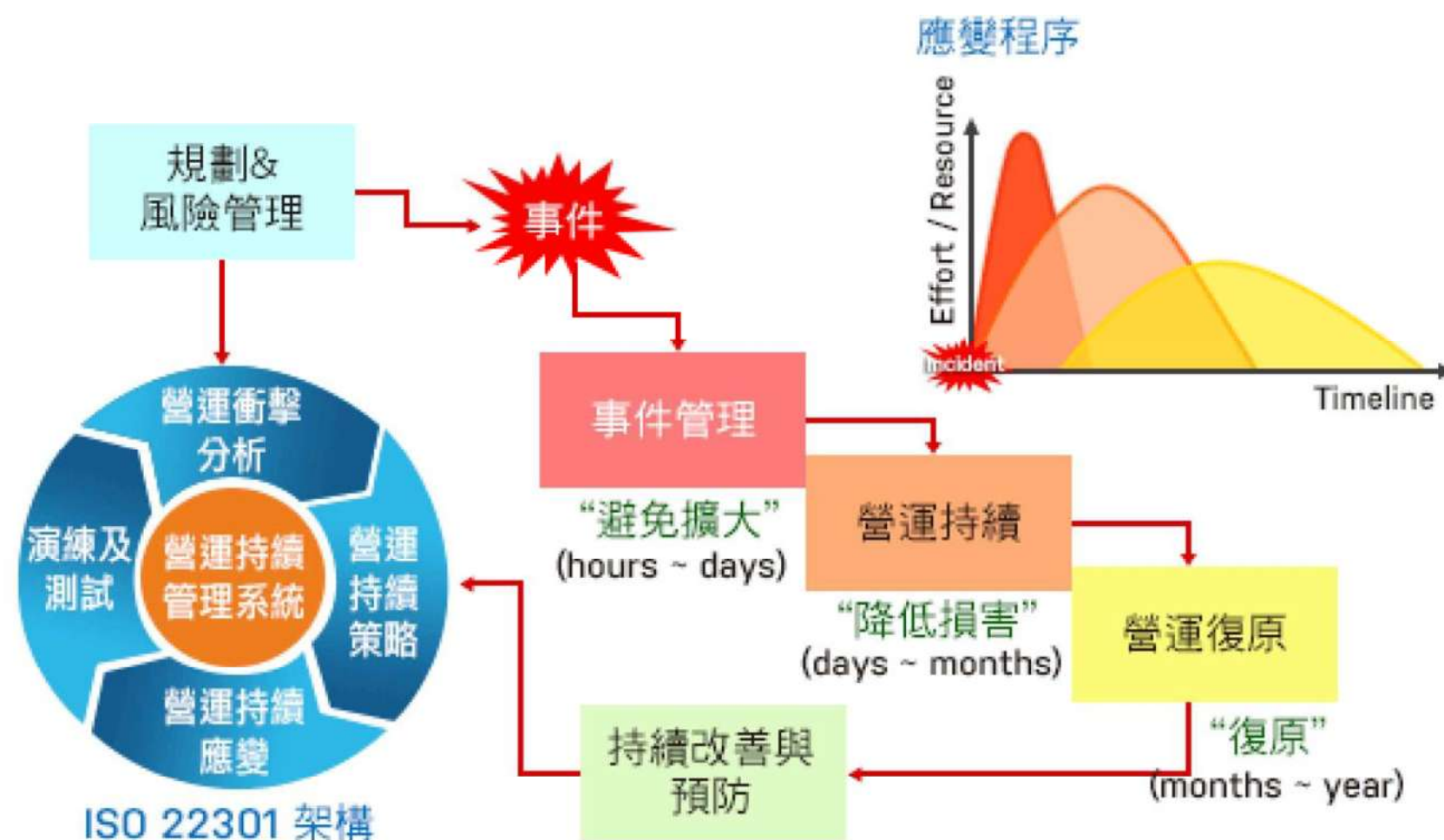
復原策略

- ◆ 目的：指導復原作業的規劃方式與規模(成本)
- ◆ 參考：關鍵業務最大容許中斷時間(MTPD)
- ◆ 必須包含下列復原策略：

- 業務流程復原策略
- 設施場所復原策略
- 供應與技術復原策略
- 使用者環境復原策略
- 資料復原策略

- ◆ 業務流程復原策略：

- 其他業務處理流程(自動 vs 人工)
- 業務處理流程重建



復原策略

◆設施場所復原策略

- Hot(數小時)、Warm(1天或更長)或Cold(數天)Site合約。
- 同業互惠合作、自建備援場所及自建分散式多重處理機制。
- 備援場所應有足夠合理的距離(避免同一災害同時受損)。

◆場所備援方案比較

場所相關準備項目	Hot Site	Warm Site	Cold Site
空間已備妥	是	是	是
電力、網路及空調已備妥	是	是	是
軟硬體已就緒	是	部份	無
資料復原	需要	需要	需要
人員	無	無	無
所需復原時間	數小時	1天或更長	數天

復原策略

◆供應與技術復原

- 網路與電腦設備
- 語音與資料通訊
- 人力資源
- 人員與設備的運送
- 作業環境(空調等)
- 資料與人員安全
- 耗材
- 文件

◆使用者環境復原

- 發展災害情況下的通報網
- 識別關鍵使用者以利關鍵業務的運作
- 必要時發展人員運送至備援場所的程序



復原策略

◆資料復原

- 備份
- 異地備份
- 異地備援

◆其他注意事項

- 備援與復原機制的選擇應考量成本效益
- 備份與備援機制的安全要求應與線上相同
- 備份與備援機制應定期測試與演練

資料備份

◆ 資料備份(backup)可分為完整備份、增量備份、差異備份

- 完整備份(Full backup)是將伺服器磁碟內全部的檔案資料進行備份的方式。
- 增量備份(Incremental backup)僅備份上次完整備份或增量備份後有變動的部分檔案。
- 差異備份(Differential backup)僅針對從上次完整備份後更動過的檔案進行備份。

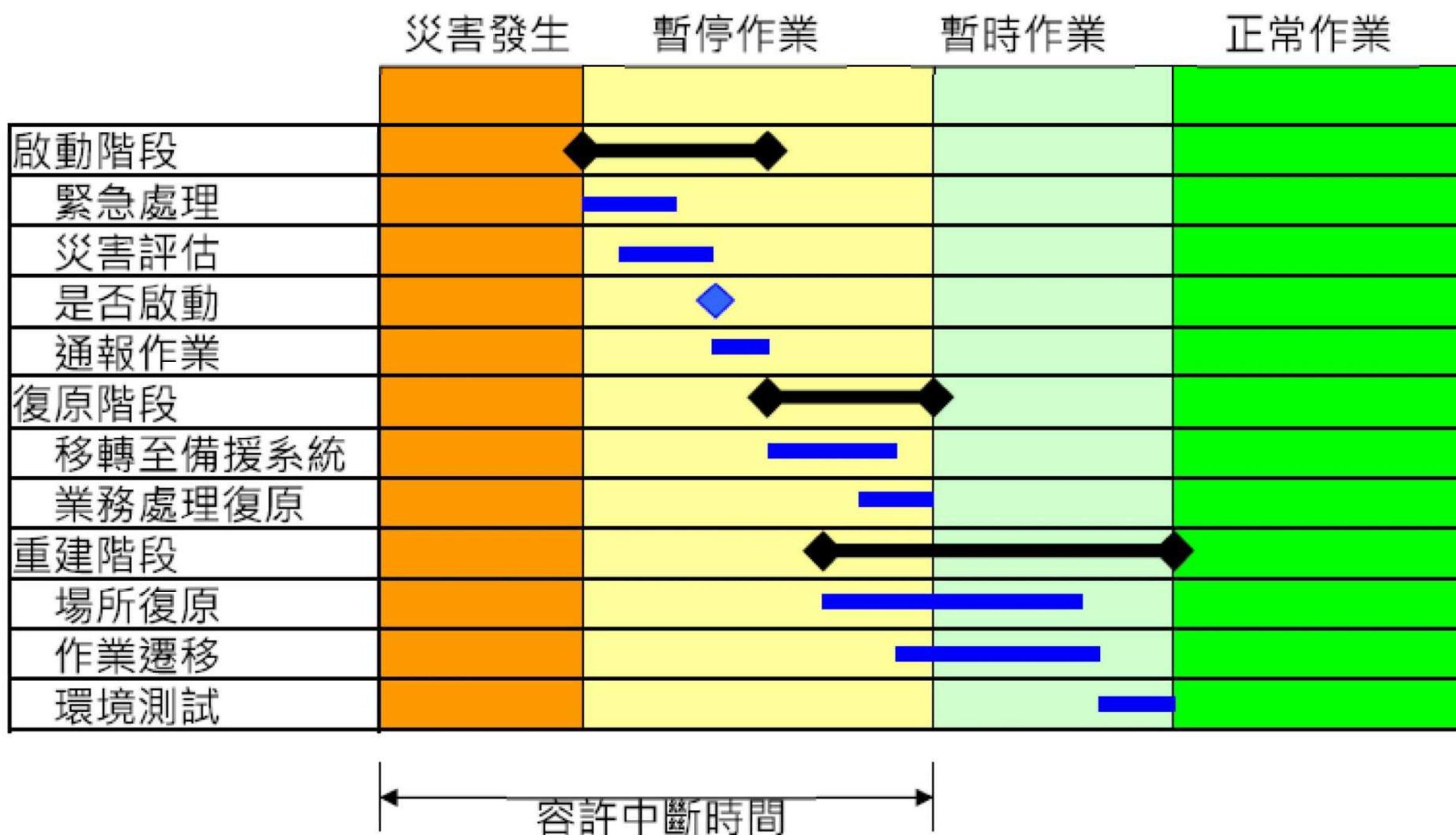
◆ 備份因儲存位置可分為本地儲存(On site storage)及異地儲存(Offsite storage)兩種。

◆ 本地儲存係指用資料中心所在地現場的儲存設備，而異地儲存則是將資料備份於和資料中心具有一定距離的地方進行備份，當發生不可避免的事故或災難而導致資料毀損，以異地儲存較具安全性，可避免原始資料與備份資料在同一事故或災難中同時受到波及，降低資料無法挽救回來的風險。

◆ 資料備份之效果可用復原點目標(Recovery Point of Objective，RPO)進行衡量，其定義是指系統復原的時間點，例如是當機前的一小時亦或是當機前的一星期做為復原時間點，當復原點目標越接近當機的時間點即代表備份之頻率越高，成本也就越高。

發展業務持續運作計畫

◆BCP時程



- 前言
 - 目標
 - 適用範圍
 - 角色與權責
 - 定義
- 啟動階段
 - 通報作業程序
 - 損害評估
 - 計畫啟動
 - 緊急處理程序
- 復原階段
 - 移轉到備援系統
 - 業務處理復原
 - 復原程序
- 重建階段
 - 場所復原
 - 環境測試
 - 作業遷移
- 附錄
 - 通報網路
 - 系統需求

發展業務持續運作計畫

◆啟動階段

- 緊急處理程序：人員疏散程序→急救步驟(CPR)→依不同災害定義相關處理程序(火災、地震及輻射等)
- 執行損害評估決定是否啟動BCP
- 復原人員的通報程序

◆復原階段

- 主要目的是讓關鍵業務回復至暫時可運作的狀態(Min Service Level)。
- 復原程序應包含系統回復至可運作狀態的每一步動作，而且必須在可容許中斷的時間(MTPD)內完成(但組織有時會自訂更短的 RTO)。

發展業務持續運作計畫

◆重建階段

- 主要目的是讓關鍵業務從暫時運作狀態，在原地|點或其他地點復到一般正常作業。
- 在重組後的新環境應執行相關系統與作業測試。
- 由較不重要的業務功能先移轉至新環境。

測試與演練

◆目的

- 檢驗BCP的可行性並補強未考量之缺陷。
- 確保在可容許中斷時間內可完成復原作業。
- 讓相關人員熟悉相關災害復原的作業。

◆測試方式

- 檢核表測試(部門個別檢視 BCP 工作)：》無法得知不同部門間的合作與溝通結果。
- 整合測試(各部門一起檢視 BCP 過程)：》無法模擬不同的災害類型或損壞情況來應變。
- 狀況模擬測試(紙上模擬災害情境與復原過程)：》缺乏實際執行復原與重建的經驗。

測試與演練

◆測試方式

- 並行測試：實際將部份系統及業務移轉到備援場所，但原場所仍持續運作。可實際測試是否能在最大容許中斷時間內復原，可能導致部份業務無法運作
- 完全中斷測試：中斷原場所系統及服務，實際模擬 BCP 的復原階段與重建階段
 - 關鍵業務必須中斷一段時間
 - 部份業務可能無法及時復原運作
 - 重建階段演練時，資料若需回存到原系統，可能導致資料錯亂

◆測試與演練的時機

- 定期(每年)
- BCP 有重大變更時可額外進行

維護業務持續運作計畫

- ◆ 目的：確保 BCP 可符合組織現況需求
- ◆ BCP 會因下列因素變成不符現況需求
 - 科技的快速變動或軟體升級
 - 組織組織變更(分工方式、合併或裁減)
 - 人員異動
- ◆ 如何確保 BCP 可符合現況
 - 指派專責人員或部門負責持續更新
 - 將計畫的審查加入組織定期稽核項目
 - 在變更控制程序中審查是否需要更新 BCP

維護業務持續運作計畫

- ◆ 在可容許中斷時間內可以復原
- ◆ 在暫時備援環境中的作業是適當可行的
- ◆ 備份資料可被成功回存
- ◆ 緊急處理人員、服務人員及合約要求人員在可
- ◆ 接受的時間內可以到達
- ◆ 小組成員瞭解現有 BCP 內容
- ◆ 小組成員可執行 BCP 的職責
- ◆ BCP 與現況需求符合

Q&A